



Product & Technical Specification

Version 1.2 — Baseline · 4 October 2026 · Confidential

Private chemistry. Intelligent discretion.

TRYST Specification v1.2 — Baseline

Private chemistry. Intelligent discretion. · *Discretion is the product.*

Version	1.2 — Baseline (stable). v1.2 adds the brand identity and account-holder-only login (06 §4)
Date	4 October 2026
Status	Stable for engineering planning and estimation. Build start remains gated on the written UK legal opinion and completed DPIA (Phase P0; see 01 §14).
Owner	Office of the Group Chief Executive → TRYST SPV (pre-incorporation)
Classification	Confidential

1. Document set

The specification is split by audience. Each document owns its topics; the others link to it rather than restating it.

#	Document	Audience	Owens
00	README (this file)	Everyone	Index, source precedence, change control
01	Product	Leadership, product, investors, counsel	Thesis, segments, modes, principles, loops, agent roles, business model, unit economics, GTM, roadmap, team, budget, KPIs, risks, compliance envelope, admission policy, liability architecture
02	Shared Contracts	Backend and frontend	Glossary, enums, verification tiers and gates, data model, API contract, event taxonomy, agent message schemas, retention, error model, requirement catalogue (FR/NFR) with owners
03	Backend	Backend, ML, security, SRE, T&S engineering	Services, stack, agents, learning models, matching pipeline, cryptography, identity split, erasure, PSI server, Guardian server side, admission control, MLOps, commerce, backend backlog
04	Frontend	iOS, Android, web, design	Two-surface strategy, client stacks, screens and flows, client discretion, client cryptography, on-device Guardian, PSI client, safety UX, copy rules, store compliance, frontend backlog
05	Terms of Service — draft 0.9.2	Counsel	Consumer terms for counsel review. Not for publication.
06	Decisions, errata and change log	Product owner, tech leads	How v1.1 reconciled its sources, resolved and open decisions, errata fixed

A combined PDF of 00–06 is at [TRYST_Spec_v1.2.pdf](#). Brand assets (logo exactly as supplied, colour tokens) are in [assets/brand/](#).

2. Sources and precedence

v1.1 merges three inputs. Where they conflict, the higher-ranked source wins unless 06 records a decision otherwise.

Rank	Source	File
A	Product & Technical Specification and Terms of Service — consolidated edition (4 Oct 2026; Part A §1–21, Part B ToS draft 0.9)	source/TRYST_Spec_and_ToS_Consolidated_2026-10-04.pdf
B	AI Discreet Relationship Platform — Developer Specification (17 Sep 2026)	source/TRYST_Developer_Specification_2026-09-17.docx
C	PRD & Business Plan draft v0.1 (4 Oct 2026)	archive/TRYST_PRD_v0.1.md

Both A and B call themselves "v1.0", so v1.1 refers to them as **Source A** and **Source B**. In v1.1, references such as [A §9.3] point to the source section a requirement came from.

3. Identifier conventions (stable across documents)

Prefix	Meaning	Defined in
S1–S6	Member segments	02 §2.2

Prefix	Meaning	Defined in
V0-V3, VC	Verification tiers	02 §3
A1-A8	Threat-model adversaries	03 §6.1
M1-M9, M6a-M6e, M7b	Models	03 §4.3
L1-L5	Admission-control layers	03 §8
FR-nnn, NFR-nn	Functional and non-functional requirements	02 §10
D-nn	Decisions	06 §2
E-nn	Errata fixed in v1.1	06 §3
G-xx	Phase exit gates and no-go conditions	01 §12-13

IDs are never reused or renumbered. A retired requirement keeps its ID with status *Retired*.

4. Change control (stabilisation rules)

1. **v1.1 is a baseline.** Changes go through a pull request that edits the owning document and adds a row to **06 §4**.
2. **Contract changes come first.** Any change to an API, entity, enum, event or schema is made in **02 Shared Contracts** before 03 or 04 depend on it.
3. **Open decisions** (D-nn, status *Open*) carry a stated default. Engineering may build against the default, and the owner must close the decision before the phase gate shown.
4. **Consistency check.** `python3 scripts/check_spec.py` checks that every FR/NFR/D/E ID referenced anywhere is defined exactly once, every FR has an owner, and relative links resolve. It must pass before merge.
5. **Version bumps:** editorial → 1.1.x; new or changed requirement → 1.2; change to a principle in 01 §4 → 2.0 (requires sign-off from the Group CEO).

01 — TRYST Product Specification v1.1

Part of the TRYST v1.1 baseline. Contracts live in 02; implementation in 03 and 04.

1. Executive summary

PRODUCT SCOPE

TRYST is designed specifically for adults who are already in a relationship and want a discreet one-off affair, a continuing extramarital connection, another couple, or a threesome. Existing-partner permission is not a condition of membership. Every person using TRYST must nevertheless be an independently consenting adult; the platform prohibits coercion, stalking, blackmail, impersonation, minors, non-consensual imagery and commercial sexual services.

Founder scope statement, verbatim (Source B; re-confirmed 4 Oct 2026). Applied through §4, §5 and D-01.

TRYST is a discretion-first connection platform for attached adults, solo adults open to couples, and couples. It covers one-off encounters, ongoing extramarital connections, couples seeking a third, and couple-to-couple connections, for all genders and orientations.

Two things make it different:

- 1. **An agent-to-agent handshake (Envoy).** It resolves intent, boundaries, logistics, discretion needs and verification parity *before* two people speak.
- 2. **A breach-assumed architecture.** End-to-end encrypted messaging, client-side encrypted media, split identity and profile stores, cryptographic erasure in under 60 seconds, and partner-collision avoidance through private set intersection. Together these make the category's defining disaster — the 2015 Ashley Madison breach — technically very hard to repeat.

Board summary [A §21]. The category leader in affairs has vacated that position under regulatory and payments pressure. The leader in non-monogamy is a browsing product with a resolution problem. The opportunity is real. The hard part is not the software but the compliance envelope, marketplace liquidity, and an acquisition-cost model that only works through invitation. Build the envelope first, seed the scarce side first, and let the agent layer earn its place against a measured control.

Gating. No engineering build starts before a written UK legal opinion and a completed DPIA (§14).

1.1 Executive product decision

Founder text, verbatim (Source B; re-confirmed 4 Oct 2026).

Build TRYST as a privacy-first, affair-specific connection platform rather than a generic dating app. Its strategic advantage is an AI relationship-intelligence layer that learns attraction, discretion requirements, availability, risk tolerance and interaction quality while deliberately collecting less identifying data than incumbents.

Decision	Specification	Why it wins
Name	TRYST	One sharp word meaning a private romantic meeting; instantly communicates the category.
Audience	Partnered adults of any gender/orientation; couples seeking a third or another couple	Clear, high-intent niche rather than mass-market dating.
Promise	Private chemistry. Intelligent discretion.	Combines emotional benefit with the functional moat.
Core modes	One-off, Ongoing, Couple+, Threesome, Couple-to-Couple	Intent is explicit before matching.
Moat	Discretion Graph + Behavioural Compatibility Engine	Learns fit without exposing identity or partner data.
Revenue	Subscription-led with credits and premium privacy	Predictable recurring revenue plus high-margin intent transactions.
Launch	Web/PWA first, then native apps subject to store review	Reduces store dependency and permits rapid privacy iteration.

ONE-SENTENCE PITCH

TRYST is the intelligent private network where attached adults and couples find precisely matched affairs, extra-relationship connections and threesome partners without exposing more of their identity than necessary.

How this decision maps onto the rest of v1.2:

Decision row	Implemented as
Core modes	One-off → SPARK; Ongoing → EMBER; Couple+ and Threesome → THIRD (Couple+ = a couple seeking a third; Threesome = a solo joining a couple); Couple-to-Couple → QUAD; plus OPEN for exploration (§5.2)
Moat	Discretion Graph = Discretion Policy + ExclusionRing + zones enforced on every read (Curtain); Behavioural Compatibility Engine = Mirror + Broker + Envoy (§7)
Revenue	"Credits" = Keys; "premium privacy" = the GHOST add-on, subject to D-05 (§10)
Launch	Web PWA is the full product and the revenue surface; native apps follow store review, approved by G-P3 (§12, §14.3)
Audience	See D-01 on unattached solos

2. Thesis and market gap

The discreet-connection market is large, proven and badly served. The incumbents monetise frustration; TRYST monetises resolution. [A §1]

Founder market thesis, verbatim (Source B §1; re-confirmed 4 Oct 2026):

The category is already validated. Ashley Madison markets private, anonymous connections and claims more than 91 million members. Gleeden uses a credit economy for extramarital connections; Victoria Milan markets a rapid-exit "panic button." The opportunity is not to prove demand but to rebuild the category around modern privacy engineering, verified authenticity, gender-neutral pricing, transparent AI and higher-quality matching.

Incumbent pattern	Observed weakness	TRYST response
Large anonymous inventory	Fake profiles, low trust and expensive dead-end messaging	Liveness, authenticity confidence and conversation-quality scoring.
Credit-heavy messaging	Revenue can conflict with real connection outcomes	Subscription provides core value; credits enhance but do not manufacture access.
Basic privacy theatre	A panic button cannot protect server-side data	Pseudonymity, data minimisation, isolated vaults, short retention and discreet billing.
Pairwise matching	Poor fit for couples and threesomes	Native multi-person matching and room consent.
Swipe engagement	High noise and fatigue	Small daily set of high-confidence, intent-aligned introductions.

Membership figures differ between sources: Source B cites Ashley Madison's claim of 91M+ members, Source A cites 80M+. Both are the company's own unaudited claims; use the current figure from Ashley Madison's site, with an access date, in any external material (E-32). "Gender-neutral pricing" supports the default in D-06.

2.1 Market

Player	Position	Observed weakness	TRYST response
Ashley Madison	Affair category leader (claims 80M+ members). Rebranded globally as a "discreet dating app" on 24 Feb 2026, moving away from married dating.	Pay-to-initiate credits (men pay to start conversations); recurring bot and cost complaints; 2015 breach (FTC: about 36M users exposed, deletion failures).	Take the affair position it is vacating, and survive the pressure through §9 and §14. Subscription-led pricing; replying is always free.
Feeld	Owens ethical non-monogamy and couple-seeks-third. Revenue £48.9M in 2024 (+26%, Companies House); 2M+ active users by 2026.	Thin free tier; high-noise discovery; a browsing product, not a resolution product.	Envoy handshake; daily curated slate; meets as the north star.
Gleeden, Victoria Milan, Illicit Encounters	Regional affair sites (credits; panic button).	Fake profiles; "privacy theatre" that does not protect server-side data.	Liveness plus age assurance for everyone; real cryptography.

Player	Position	Observed weakness	TRYST response
3Fun / #Open / swinger communities	Couples and thirds niche.	Fake "couples", moderation gaps, dated UX.	Mandatory dual-verified couple profiles (VC).
Mainstream apps (Tinder, Hinge, Bumble, Grindr)	Mass market.	Not discreet; exposure through social graphs.	ExclusionRing; decoy skin; no social login.

Third-party figures are as reported by the sources cited in Source A and have not been independently audited.

2.2 Four failures TRYST fixes

Source: A §1

Failure	Why it persists	TRYST answer
Stated $\neq$ real intent	Profiles are self-authored marketing	Behaviour-learned RevealedPreferenceVector matched against IntentVector; divergence is a feature
200 messages, zero meets	Engagement-maximising ranking rewards long unresolved threads	Envoy handshake pre-qualifies; the reward function penalises time in app
Attention collapse	Rich-get-richer ranking; couples broadcast to everyone	Inbound caps, Gini constraint, asymmetric Key pricing
Discretion as marketing	Retention by default and server plaintext are cheaper	E2EE, cryptographic erasure, token-only verification, PSI ExclusionRing

3. Name and brand

Source: A §2

TRYST — *a private, prearranged meeting between lovers*. One syllable, five letters, no explanation needed, and deniable on a lock screen. Tagline: **Private chemistry. Intelligent discretion.** Internal line: **Discretion is the product.**

- **Brand codes:** oxblood and gold on night; serif display, tight tracking. No pink, hearts, silhouettes or lipstick. Reference: a private members' club, not a nightclub.
- **Fallback names** if trademark clearance fails: ASIDE, DUPLEX.
- **Domains:** tryst.app / tryst.co / trystapp.com plus defensive registrations before any UKIPO Class 9/45 filing becomes public.

3.1 Logo



The master logo is `assets/brand/tryst-logo.png` (1254 × 1254 px, transparent background), supplied by the founder (D-19).

- **Use it exactly as supplied.** Do not redraw, recolour, crop, stretch, re-shadow or separate the mark from the wordmark. The repository keeps the original file byte-for-byte (SHA-256 5f2ceb55...eae2761).

- **Background:** the logo is designed for the dark night ground (§3.2), and is only placed on night, oxblood-deep or oxblood.
- **Never shown where it would expose a member (P3, P9):**
 - on a device in decoy mode;
 - on the lock screen or in notifications;
 - in the app-switcher snapshot;
 - in billing descriptors;
 - in the home-screen icon of a member who has chosen a decoy skin;
 - in Share My Plan messages.
- **Where it appears:**
 - the web PWA (landing page, sign-in, header);
 - inside the native apps after unlock;
 - store listings, subject to the sanitised-store rules (§14.3);
 - investor and press materials.

3.2 Colour palette

The palette is sampled from the logo. Tokens live in `assets/brand/tokens.json` and `assets/brand/tokens.css`.

Token	Hex	Role	Contrast on night
night	#0B0607	Primary background	—
oxblood-deep	#3F0000	Deep surfaces, pressed states	—
oxblood	#560001	Brand surface, primary buttons	1.34 (surfaces only)
oxblood-light	#702A2E	Hover, borders, dividers	1.97 (never text)
bronze	#836042	Secondary lines, disabled states	3.56 (large text only)
gold	#CB944F	Accent, links, icons, headings	7.56 AA/AAA
champagne	#F5D3AC	Highlight text, active states	14.18
cream	#FCF2DD	Body text; light surface (replaces "bone")	18.1

Text pairs that pass WCAG 2.2 AA (NFR-07):

- cream, champagne or gold on night;
- cream (13.5), champagne (10.6) or gold (5.65) on oxblood;
- oxblood on cream (13.5).

Oxblood and oxblood-light are never used for text on dark grounds.

4. Operating stance and principles

4.1 Stance

Source: A §1

We are indifferent to your marriage; we are absolutist about consent and safety on our surface.

TRYST does not police whether a member's partner knows; that is unverifiable and not the platform's business. It does enforce, without exception:

- Verified adults only, through highly effective age assurance.
- Consent from every party *on the platform*. Couples are dual-verified; no one is listed by a partner without co-signature. No permission is required from anyone not on TRYST.
- Zero tolerance for image abuse, sextortion, coercion, commercial sexual services, and minors.

4.2 Product principles (changing one requires v2.0)

#	Principle	Source
P1	Resolution over engagement. Optimise for confirmed, positively rated meets (QCAM), never time in app or message volume.	A §6.4, §18
P2	Hard limits are inviolable. No learned signal can surface a candidate who violates a hard limit, exclusion zone or structure incompatibility. Enforced by tests, not policy.	A §6.2
P3	Breach-assumed by design. Assume breach, subpoena, and a suspicious partner holding the phone.	A §9

#	Principle	Source
P4	Agents never impersonate. Agents negotiate only with other agents; every Brief is labelled as machine-generated; only a double human accept opens a thread.	A §5.4
P5	Stated preference keeps a floor. Revealed behaviour never drops stated preference below 15% weight; members can view, correct and reset learning.	A §6.2, B FR-010
P6	No safety theatre. No "safe", "vetted" or "background-checked" badges, ever. Only factual, dated statements.	A §19.2, §19.8
P7	Safety beats discretion in an emergency. Panic preserves and releases what emergency services need, regardless of retention settings.	A §19.7
P8	Revenue ethic. No advertising, data sale, affiliates, fake profiles, unreadable credit mechanics, engagement paywalls, or charging for deletion or data access. Replying is always free.	A §15, B §11
P9	Truthful privacy claims. Never promise an affair is undetectable. Disclose the limits (device owner, bank, network, recipient screenshots, legal process) and the declared exceptions (ban anchors, legal holds).	B §4, A §19.3

4.3 Never

- Never the "cheat better" message; the positioning is "Discretion is the product." [A §16]
- Never a "catch a cheater" feature, partner search or exposure tool.
- Never random or anonymous chat; messaging is between matched members only. [A §14.3]
- Never operate in markets that criminalise adultery or same-sex conduct, and never in Africa or MENA under any brand. [A §14.5]

5. Segments, modes and intent shapes

5.1 Segments

Source: A §3

Every segment is first-class in the data model.

Code	Segment	Job to be done	Primary anxiety
S1	Attached, undisclosed	Meet one person discreetly without changing my primary life	Exposure
S2	Attached, disclosed / open	Quality connections without re-explaining my structure	Judgement, wasted time
S3	Couple seeking a third	Someone both of us want, who wants both of us	Ghosting; friction between partners
S4	Solo open to couples	Be treated as a person, not a utility; a veto that is respected	Harassment volume; bait-and-switch
S5	Couple seeking a couple	Four-way compatibility with low coordination cost	Coordination collapse
S6	Curious / never acted	Find out whether this is for me, at low risk	Committing too early; discovery

S4 is the scarce asset. S4 supply decides whether S3 and S5 have a product. S4 inbound is rationed, priced and capped (03 §5.4). Any ranking change that pushes S4 inbound above the cap is a regression, whatever it does to session metrics.

Solo members may be attached or unattached. Partner awareness is self-declared, never verified, and never shown to others. (D-01)

5.2 Modes (member-facing) ↔ intent shapes (data)

Source B's mode names are kept as the **member-facing labels**; Source A's intent shapes are the **canonical data values** (02 §2.3).

Mode (UI)	Intent shape(s)	Typical segments	Notes
SPARK	one_off	S1, S2, S4, S6	Matched on availability, distance and chemistry
EMBER	recurring, ongoing	S1, S2	Matched on cadence, emotional depth, communication windows

Mode (UI)	Intent shape(s)	Typical segments	Notes
THIRD	third	S3 ↔ S4	Couple profile must be VC; the third is an equal member with a respected veto
QUAD	couple	S5 ↔ S5	Four independent verified accounts; match only after each couple's veto mode is satisfied
OPEN	exploratory	S2, S6	Member picks allowed configurations and visibility

A member may enable several modes, each with its own visibility and filters.

6. Product loops

Source: A §4

Loop	Cadence	Flow
A — Intake	Once (~7 min, conversational)	Age assurance → Cartographer interview → IntentVector v0 → ExclusionRing enrolment → Discretion Policy → first slate
B — Discovery	Daily (< 6 min per session target)	Curated slate (up to 18 cards, 15% exploration) → Intent sent (costed) / pass / save → Mirror updates RevealedPreferenceVector → slate recomputed
C — Handshake (the product)	Per mutual intent	Envoy A ⇄ Envoy B negotiate over a fixed schema → asymmetric Brief to each human → accept / decline / amend → E2EE thread opens only on double accept
D — Resolution	Per connection	Thread → logistics agreed → Safe Meet checklist → meet confirmed → Aftercare prompt at 48 h → reward signal
E — Discretion	Continuous	Curtain scores session risk → geofence, collision suppression, notification masking, retention enforcement

Loop C is the product. If it does not measurably raise meets per intent sent over a control cohort (gate **G-P2**), TRYST is a me-too and should not raise a Series A.

7. Agents (roles)

Seven agents, each an independently deployable service with its own tool surface, memory scope, policy file and eval suite. They talk over a typed internal bus, never by passing free text. [A §5] Implementation: 03 §3.

Agent	Role	Autonomy boundary
Cartographer	Conversational intake → signed IntentVector; re-run quarterly or on drift	Member confirms every structured field [B]
Mirror	Behaviour learning; sole writer of RevealedPreferenceVector	Approved features only; message content never used
Broker	Retrieval and ranking under hard gates and fairness constraints	Cannot bypass Stage 0 gates; paid status cannot override eligibility
Envoy	Agent-to-agent handshake; asymmetric Briefs; logistics and timing negotiation	Never talks to a human as the member; cannot open a thread; output is advisory
Curtain	Discretion risk; owns and enforces the versioned Discretion Policy	May tighten exposure automatically; may never loosen it [B]
Guardian	Safety; veto over every other agent	No permanent action without a named human; never reads message content server-side
Aftercare	48 h private outcome capture → reward	Never shown to the counterparty; never a public rating

Two release-gate functions that are not agents: **Privacy Auditor** (continuous access, retention and model-leakage tests; can block a release) [B] and the **agent eval harness** (03 §9).

8. Trust, verification and admission policy

8.1 Verification ladder

The tier definitions and what each one unlocks are canonical in 02 §3. In summary:

- **V0** = contact handle, onboarding only.
- **V1** = liveness.
- **V2** = highly effective age assurance. **Required for discovery, intents, threads, media, Envoy and meets (E-01).**
- **V3** = optional bank or digital ID.
- **VC** = couple co-signature: both partners independently at V2, each confirming from their own device.

VC is the most important trust feature in the product. It will cost 20–30% of couple sign-ups in year one. Pay it.

8.2 Screening reality and admission control

Source: A §19

In the UK you cannot lawfully buy sex-offender or criminal-record screening for platform users (ViSOR is not accessible; DBS checks are employer-only). TRYST builds five-layer admission control instead (03 §8):

Layer	What it does
L1 Identity binding	One human, one account, permanently: liveness challenge, ID match through the provider, device attestation, payment fingerprint, £9.99 refundable deposit
L2 Ban anchor	One-way identifiers that survive deletion. The declared exception to erasure.
L3 Voluntary attestation	Self-submitted Basic DBS shown as a dated fact; Clare's Law explainer (answer never asked for or stored); conduct declaration at V2
L4 Behavioural detection	Guardian M6a–M6e and M7b; most dangerous users have no record, but they do have a pattern
L5 Consortium	Industry hash sharing (e.g., Online Dating Association) of anchors plus reason codes only; gated on competition-law and data-protection opinions

"Declared unsafe" grounds (auditable): (1) self-declared intent to harm or coerce; (2) corroborated reports from two or more independent reporters; (3) a court order (SHPO, restraining or non-molestation order); (4) law-enforcement notification; (5) a model signal confirmed by human review; (6) a knowingly false conduct attestation.

Ladder: warn → shadow-limit → suspend → permanent ban + Ban Anchor → law-enforcement referral. Grounds 1, 3 and 4 go straight to permanent.

Due process: a named human makes every permanent decision; appeals go to a different reviewer within 10 working days; reporter-reputation scoring (retaliatory or coordinated reporting is itself removable — suspicious spouses and rejected counterparties are predictable abuse vectors); the transparency report publishes the overturn rate.

8.3 Safety floor

- **Safe Meet:** public venue first; check-in timer with silent escalation.
- **Share My Plan:** encrypted, unbranded, auto-deleting share with a trusted contact.
- **Panic:** escalation to 999 with location, separate from the discretion **Burn** control (E-21).
- **Emergency override:** safety beats discretion (P7).
- **Victim-support routing** after an incident.
- **24/7 T&S rota** from P3, with published SLAs.

9. Discretion promise

TRYST minimises platform exposure. It cannot guarantee secrecy from a device owner, bank, employer, network administrator, recipient screenshot, legal process or a determined third party, and it says so (P9).

The design starts from the eight adversaries in 03 §6.1:

- A1 partner holding the device — daily case
- A2 shared bank statement
- A3 social-graph recognition
- A4 mass breach — existential
- A5 extortion by a counterparty
- A6 civil discovery in divorce
- A7 insider

- A8 face-search de-anonymisation

Member-facing controls are in 04 §5. Retention defaults are canonical in 02 §7.

10. Business model and unit economics

10.1 Principle

Source: A §15.1

Charge for agency and discretion; make resolution the profitable outcome. Subscription plus success-weighted retention, never pay-per-message. The economic model and the loss function must agree.

10.2 Tiers (UK)

Tier	Price	Includes
Verified (free)	£0 + £9.99 refundable deposit (credited 100% as Keys)	Full profile; be discovered; reply to anyone free ; 3 outbound intents a week; Envoy handshake on mutual intent; full safety suite and core discretion suite
TRYST+	£24.99/mo · £14.99/mo billed annually	Unlimited intents, filters, incognito, travel mode, extended media, read-receipt control
ENVOY	£49.99/mo	The agent tier: Envoy <i>proposes</i> outreach and pre-qualification, screens risk, negotiates logistics. Every outbound intent needs a one-tap human approval (D-04)
DUO	£39.99/mo per couple	Linked VC profile, dual-consent controls, joint-veto model, third-screening Envoy
Keys	£9.99 / 60	Non-subscribers: intent = 5 Keys solo→solo, 15 Keys couple→solo; fully refunded on reply
GHOST add-on	£7.99/mo	Advanced discretion: multiple decoy skins, custom TTLs, extended ExclusionRing heuristics. Core decoy, duress PIN, Burn, masking and voucher billing stay free (D-05)

Source B's Black / Duo £34.99 / Signals / Vault+ / Concierge Black tiers are superseded (E-14). Concierge is deferred beyond P4.

10.3 Unit economics (illustrative; replace with beta cohorts)

Source: A §15.3

Metric	Value
Blended CAC per sign-up (paid + referral, UK)	£38
Sign-up → V2 verified	52%
Verified → payer (month 3)	11%
Blended ARPPU	£31.50/mo
Payer gross churn	19%/mo (average life 5.3 months)
Gross revenue per payer (lifetime)	£167
less PSP (high-risk, 5.0%) / verification (2 × £1.10) / infra + inference	−£8 / −£2 / −£14
Contribution per payer	£143
CAC per payer at £38 per sign-up ($£38 \div 0.11 \div 0.52$)	£664 — paid acquisition alone does not work

Corrected viability thresholds (E-03): break-even blended CAC per sign-up = £143 × payer rate × 0.52.

Verified → payer	Break-even CAC per sign-up	CAC for 3× LTV:CAC
11%	£8.18	£2.73
16%	£11.90	£3.97
18%	£13.38	£4.46

Source A's "< £12" target is only viable at a payer rate of about 16% or more. Two levers decide the business; track both weekly from beta day one:

1. Raise verified → payer toward 18% (ENVOY is the instrument).
2. Drive blended CAC down through invitations and organic channels.

Treat paid acquisition as a seeding cost, never a growth engine.

11. Liquidity and go-to-market

Source: A §16

1. **Density gate (G-City-1).** No city opens below 2,000 verified profiles; a waitlist beats an empty grid.
2. **Balance gate (G-City-2).** Throttle the oversupplied side to keep the ratio at or below 2.2:1 per city, with a genuine, moving waitlist.
3. **Seed the scarce side first.** Invite waves and founding-member status for S4 (and, subject to D-06, under-represented cohorts) with free ENVOY for 6 months.
4. **Invite-only for 9 months.** 3 invites per member, refreshed monthly for members in good standing. Referral rewards never reveal the referrer to the invitee [B].
5. **Cities:** London → Manchester → Birmingham → Brighton → Dublin. Not nationwide.
6. **Channels:** assume Meta and Google reject the ad account. Use podcast host-reads in adjacent verticals, ENM and relationship creators, technology-led PR (agent handshake, breach-proof architecture), and an editorial presence. Never synthetic personas or staff posing as members [B].
7. **Positioning:** "Discretion is the product." Never "cheat better."

Markets: launch UK + IE · wave 2 NL, BE, DE, SE, DK, ES, PT · wave 3 CA, AU, NZ. The US is out of scope (E-16). Every market needs its own written legal opinion.

12. Roadmap, team, budget and phase gates

Source: A §17

Phase	Window	Scope	Exit gate
P0 Legal & foundation	M0-M2	SPV, counsel, DPIA, OSA assessments, PSP + backup MID, two age-assurance providers, threat model	G-P0: SPV incorporated · written counsel opinion · DPIA complete · OSA risk assessments drafted · high-risk PSP + backup MID approved · two assurance providers contracted · threat model signed off
P1 Core MVP	M2-M6	Loops A, B, D; E2EE; V2 gating; VC co-sign; Guardian baseline (on-device); deletion and DSR machinery; web PWA + native shells. No Envoy — this is the control cohort	G-P1: closed beta in London with 2,000 verified · erasure < 60 s p99 · no-go list (§13.2) clear
P2 Differentiator	M6-M10	Envoy, Mirror v1, ExclusionRing PSI	G-P2: meets per intent sent up ≥ 40% vs the P1 control. If not met, stop and rethink
P3 Public UK + IE	M10-M15	Invite-only public launch; DUO + GHOST; native apps approved on both stores; 24/7 T&S	G-P3: 25,000 verified · payer rate ≥ 11% · both stores approved
P4 EU wave 2	M15-M24	NL/BE/DE/SE/DK/ES/PT; per-market opinions; localised assurance and Guardian	G-P4: 150,000 verified · contribution-positive

Source B's phase-level exit criteria are folded into the gates above and into the phase backlogs in 03 §12 and 04 §10.

Team to P3 (17):

- **Product & engineering (12):** Head of Product · Principal Engineer, security-led (**hire first**) · 2 Backend (Go) · iOS · Android · Web · 2 ML/Agents · Data Engineer · Security Engineer · Design.
- **Trust, legal & growth (5):** Head of Trust & Safety (**hire in P0**) · 2 T&S ops · DPO/Counsel (fractional until P2) · Growth/Community.

24-month budget ≈ £5.9M:

Line	Amount
People	£3.4M
Legal, DPIA, counsel	£260k
Age assurance	£180k
Infra + inference	£420k
Security audits	£150k
Seeding & community	£480k
PSP reserves & fees	£220k

Line	Amount
Contingency (15%)	£780k

Plus insurance of £85-140k a year at P3 scale (§15.3), which is not in Source A's total. **Plus biometric login checks** (v1.2): an estimated £0.10-0.60 per mobile MAU per month, pending the vendor quote (03 §6.7).

13. KPIs, no-go conditions and risk register

13.1 North star and KPIs

Source: A §18

QCAM — Quality Connections per Active Month: confirmed meets with a positive aftercare score, per active member, per month. If a change raises engagement and lowers QCAM, it does not ship.

Metric	P1	P3
QCAM	0.18	0.45
Meets per intent sent	1.8%	4.5%
Mutual reply rate	22%	34%
Inbound Gini (per city, per segment)	< 0.60	< 0.55
Gender ratio (per city)	≤ 2.2:1	≤ 2.0:1
S4 30-day retention	45%	62%
Report rate per 1k threads	< 12	< 6
V2 completion	52%	68%
Chargeback ratio	< 0.65% always (above 0.9% the MID is lost)	
Erasure latency	< 60 s p99	

Secondary (Source B): qualified reciprocal conversations per 1,000 verified weekly active members; exposure incidents; location-inference success in red-team tests; notification leakage; calibration and hard-boundary violations (target 0).

13.2 No-go conditions

Do not launch or scale if any of these hold. Each is backed by an automated or audited test (03 §9). [B §14, A]

ID	Condition
G-NG-1	Private media can be accessed outside an active reveal grant
G-NG-2	Deletion or erasure claims are not technically true (including the declared exceptions)
G-NG-3	Exact location can be triangulated in red-team testing
G-NG-4	Age assurance is not "highly effective" across all four Ofcom criteria, or any gated surface is reachable below V2
G-NG-5	A couple profile can represent an unverified person or be co-signed from one device
G-NG-6	High-severity reports lack 24/7 response within published SLAs
G-NG-7	Ranking violates any hard limit, exclusion zone or ExclusionRing pair
G-NG-8	Any third-party analytics, advertising or attribution SDK is present in a client
G-NG-9	Staff can read message content
G-NG-10	Any login or recovery path issues a session with fewer factors than 02 §3.3 requires, or allows SMS/email/staff-assisted sign-in

13.3 Risk register

Risk	Severity	Mitigation
Breach (existential)	Critical	E2EE, identity split, cryptographic erasure, short TTLs, zero standing access, quarterly pen test, annual red team on A4/A7, rehearsed 72 h playbook
App-store rejection or removal (Apple 1.1.4)	High	Sanitised store build; explicit media web-only; matched-only messaging; web-first revenue
Merchant account loss	High	Backup MID from day one; alert at 0.5% chargebacks; Ethoca/Verifi; one-click cancel; pre-renewal notice; voucher path

Risk	Severity	Mitigation
Ofcom enforcement	High	Two assurance providers; inbox-level gating; documented assessments; named accountable manager; quarterly compliance review
Liquidity failure in month 4	High	Density and balance gates; scarce side first; invite-only
Envoy does not move meets per intent	High	P1 control cohort; G-P2 at +40%; kill the thesis honestly
Agent seen as a bot / impersonation scandal	High	P4; labelled Briefs; publish the design
Harm incident attributed to the platform	High	T&S in P0; 24/7 from P3; published SLAs; Safe Meet; transparency reporting
CAC model unviable	High	\$10.3 thresholds; invite loop; weekly tracking
Reputational contagion to parent group	Medium	Ring-fenced SPV, brand, counsel, cap table and PR
Feed or Match Group ships an agent layer	Medium	Speed to P2; the moat is discretion architecture plus the aftercare dataset
Two-factor biometric login hurts conversion or excludes disabled members	Medium	Fast provider flow (NFR-16); 30-day sessions; accessible alternative (D-17); measure login drop-off weekly
Guardian false positives on consensual kink	High	Trajectory-not-vocabulary design; matched-pair ship gate (03 §7)

14. Compliance envelope

This section gates the build. Everything here needs sign-off from UK counsel experienced in the OSA and Article 9; it says what to instruct counsel on, not what they will conclude. Statutory positions and commencement dates must be checked as at the date of use. [A §14]

14.1 Online Safety Act 2023

TRYST is in scope as a user-to-user service. Ofcom treats dating services as posing a risk of significant harm to minors and published dating-specific guidance in May 2026.

Required before public launch:

- illegal-content and children's-access risk assessments;
- highly effective age assurance meeting all four criteria (accuracy, robustness, reliability, fairness), **applied to the inbox and media, not just sign-up**;
- clear terms, in-app reporting, rapid review and removal;
- controls mapped to Ofcom's named dating risks (romance fraud, intimate image abuse, sextortion, harassment, stalking, grooming);
- a named accountable senior manager.

Penalties reach the greater of £18M or 10% of global turnover, with possible criminal liability for senior managers.

14.2 UK GDPR / DPA 2018

- **Article 9 explicit consent** — granular, separate from the ToS, withdrawable, recorded in the consent ledger.
- **DPIA mandatory** — two triggers: large-scale special-category data and systematic evaluation.
- **Minimisation as architecture** — no legal name, exact DOB, ID images or coordinates.
- **Article 22** — human review path for suspensions.
- **DSR machinery from sprint one.**
- **Residency** — UK/EU only; no US sub-processor for Article 9 data without a TIA.
- **Breach playbook** — 72 h, rehearsed twice a year.
- **Article 10 conviction data and the ban-anchor lawful basis** — DPA Sch. 1 Pt 2 para 18 assumed; counsel must confirm.

14.3 Distribution — two-surface strategy

- **Apple 1.1.4** rejects "hookup" apps that may include pornography or facilitate prostitution.
- **Google Play** requires minor-blocking for dating apps and restricts anonymous or random chat.

Native store builds are therefore **sanitised**: no nudity or explicit copy, matched-only messaging, 18+, "discreet dating" positioning. The **web PWA** carries the full product: explicit media behind V2, and all billing. Details: **04 §2**.

14.4 Payments

- MCC 7273, high-risk; Visa Integrity Risk Program Tier 1 registration; dedicated high-risk acquirer (3–7%); Stripe, Square and PayPal are not usable.
- **Spousal chargebacks** are the category-specific risk. Mitigations: neutral but truthful descriptor with a customer-service URL, offline voucher/gift-code path, pre-renewal email, one-click cancel, Ethoca/Verifi alerts, backup MID, correct MCC.
- **DMCC Act 2024 subscription regime:** commencement has moved repeatedly; build to the full regime now.

14.5 Jurisdiction gating and structure

- Hard geo-block at the edge and at sign-up for any market that criminalises adultery or same-sex conduct, or prohibits the category.
- Travel into a blocked market auto-locks the app to the decoy.
- Ring-fenced SPV with its own controller registration, brand, counsel, cap table and PR, and no public link to the parent group.

15. Liability, claims and insurance

Source: A §19.8, §20

15.1 Claims discipline

Never say	Say
"Background checked", "Safe", "Vetted"	"Identity verified", "Age assured"
"No sex offenders on TRYST"	"We permanently remove and block re-registration where we find harmful conduct"
"Screened for domestic violence"	"We detect and act on coercive and abusive behaviour, and we'll show you how to use Clare's Law"
"Guaranteed real people"	"Every member completes liveness and ID verification"
Green "verified safe" tick	Factual, dated attestations only

Overclaiming is a misleading commercial practice under CPUT and the DMCC Act, and the first thing a claimant's solicitor will point to.

15.2 Liability architecture

- **CRA 2015 s.65** bars excluding liability for death or personal injury caused by negligence (including mental impairment). Under s.65(2), agreeing to a term does not mean accepting a risk.
- **s.62** strikes unfair terms in full.

The draft ToS therefore uses narrow, honestly carved limits:

- correct characterisation of the service;
- an explicit list of what is and isn't verified;
- no liability for consequences to members' relationships;
- a financial cap of the greater of 12 months' fees or £100;
- a load-bearing "what we do not exclude" clause.

Keep out: death/injury exclusions, "use at your own risk", mandatory arbitration or class waivers, unilateral no-notice amendment, any screening implication, and forfeiting Keys before an appeal concludes.

The real protection is §8, not the clauses: liability will turn on whether TRYST took reasonable care. The ToS draft is 05.

15.3 Insurance and structure

Cover needed:

- cyber and data liability, sized for an Article 9 breach;
- tech E&O / professional indemnity;
- public and product liability;
- D&O (OSA named-manager exposure);
- media liability.

The SPV provides structural containment. Indicative premium at P3 scale is **£85-140k a year**.

02 — TRYST Shared Contracts v1.1

Part of the TRYST v1.1 baseline. This document is the **single source of truth** for everything both backend (03) and frontend (04) depend on. Change it first (00 §4).

1. Conventions

Topic	Rule
Contract formats	Edge API: OpenAPI 3.1 (contracts/openapi/). Internal gRPC, the agent bus and events: Protobuf in the schema registry (contracts/proto/). Generated client and server types; no hand-written DTOs (D-07).
IDs	UUIDv7, opaque, never sequential or enumerable. Prefixed in logs only (usr_, prf_, thr_).
Time	RFC 3339 UTC on the wire. Availability windows carry an IANA tz.
Money	Integer minor units + ISO 4217 ({ "amount": 2499, "currency": "GBP" }).
Location	Geohash-5 (~5 km) or coarser on the wire and at rest. Exact coordinates are sent to the server only by the Panic flow (§5.8).
Age	age_band only (18-24, 25-29, 30-34, 35-39, 40-44, 45-49, 50-59, 60+). No DOB anywhere.
Free text	Everything a counterparty writes (bios, messages, agent turns) is untrusted input : schema-validated, never executed or interpreted as instructions.
Versioning	URL major version (/v1). Additive changes only within a major version. Enum additions are additive; clients must tolerate unknown values.

2. Glossary and enumerations

2.1 Glossary

Term	Definition
Member	A person with a TRYST account (one human, one account).
Entity	The matchable unit: a solo profile or a couple profile.
Couple profile	An entity linking two members, each verified to V2 and each co-signing from a distinct device (VC).
Intent	A costed outbound expression of interest from one entity to another.
Mutual intent	Both entities have sent an intent to each other. In P2+ it triggers a handshake.
Handshake	Envoy-to-Envoy negotiation over a fixed schema (§6).
Brief	The asymmetric, agent-generated summary each side receives after a handshake. Always labelled as machine-generated.
Thread	An E2EE conversation (MLS group) between the entities' members. Opens on double accept (P2+) or mutual intent (P1 control).
Keys	Prepaid credits. Spent on intents; refunded in full on reply.
Discretion Policy	A member's versioned privacy configuration, enforced on every read path (§6.4).
Reveal grant	A recipient-specific, expiring, revocable permission to view a media item or move up the reveal ladder.
ExclusionRing	A set of bidirectional, silent suppression pairs (PSI contacts, heuristics, manual).
Exclusion Identifier / Ban anchor	An irreversible one-way identifier kept after deletion for permanently removed members. The declared exception to erasure.
Burn	Discretion control: wipe local data, revoke device keys, sign out everywhere.
Panic	Safety control: escalate to emergency services with live location. Never the same control as Burn.
QCAM	Quality Connections per Active Month (north star; 01 §13).

2.2 Segments

segment ∈ {S1, S2, S3, S4, S5, S6} — definitions in 01 §5.1. A solo entity is S1, S2, S4 or S6; a couple entity is S3 or S5.

2.3 Intent shapes and modes

intent_shape (data)	Mode label (UI)	Entity pairs allowed
one_off	SPARK	solo↔solo
recurring	EMBER	solo↔solo
ongoing	EMBER	solo↔solo
exploratory	OPEN	any, subject to seeking
third	THIRD	couple(S3)↔solo(S4)
couple	QUAD	couple(S5)↔couple(S5)

2.4 Other enumerations

Enum	Values
structure	attached_undisclosed, attached_disclosed, open_relationship, unattached, couple_seeking_third, couple_seeking_couple, prefer_not_to_say
visibility	public (discoverable to eligible), matched (visible only to matches), incognito (discoverable only after own outbound intent)
veto_mode (couple)	either (either partner can decline), both (both must accept before an intent or decision counts)
handshake_decision	pending, accept, decline, amend
intent_state	sent, queued_inbound_cap, delivered, replied, declined, expired, refunded
desire_tag_level	yes, curious, no
consent_kind	art9_processing, media_view, meet, couple_link, retention, conduct_attestation, safety_training_use, biometric_login
reveal_scope	alias, blurred_gallery, photo_set, voice, video (the reveal ladder, in order)
report_category	minor, ncii, sextortion, coercion, threat_violence, stalking, romance_fraud, commercial_sex, harassment, impersonation, exposure_threat, other
enforcement_action	warn, shadow_limit, suspend, permanent, law_enforcement_referral
unsafe_ground	g1_self_declared, g2_corroborated_reports, g3_court_order, g4_law_enforcement, g5_model_confirmed, g6_false_attestation
guardian_reason_code	m6a_coercive_control, m6b_boundary_violation, m6c_off_platform_pressure, m6d_identity_location_pressure, m6e_image_coercion, m7_authenticity, m7b_ban_evasion, payment_solicitation
tier (commerce)	verified_free, tryst_plus, envoy, duo; add-on ghost

3. Verification tiers and gates

3.1 Tiers

Tier	Method	Retained	Source
V0	Email or phone OTP; device attestation	HMAC contact hash; device key	A §8.1
V1	Liveness selfie with randomised challenge, matched to profile photos	Boolean + match score. No biometric template.	A §8.1, §19.3
V2	Highly effective age assurance through a third-party provider (one of two, abstracted), including an ID-document match	is_adult boolean + provider token + ban-anchor candidates (§4.1). No ID image, no DOB.	A §8.1, §19.3 L1
V3	Optional open banking or digital ID	Boolean + token	A §8.1
VC	Couple co-signature: both partners at V2, each confirming from their own distinct device	Link record, both profile IDs, device hashes	A §8.1

3.2 Capability gates (enforced server-side; mirrored in UI)

Corrected in v1.1: Source A's tier table let V1 send intents and open threads, which contradicted ToS cl. 5.1, Source B FR-001 and the OSA inbox requirement. V2 is now the gate for all interaction (E-01).

Capability	V0	V1	V2	V3	Couple (VC)
Onboarding, Cartographer intake, discretion setup, waitlist	✓	✓	✓	✓	✓

Capability	V0	V1	V2	V3	Couple (VC)
See other members' profiles (slate)	—	—	✓	✓	✓
Send intents / receive deliveries	—	—	✓	✓	✓
Envoy handshake / Briefs	—	—	✓	✓	✓
Threads (E2EE)	—	—	✓	✓	✓
Media exchange; explicit media (web only)	—	—	✓	✓	✓
Meets, Safe Meet, Share My Plan	—	—	✓	✓	✓
Trust badge; set min_counterparty_tier = V3	—	—	—	✓	—
Publish couple profile	—	—	—	—	requires both partners at V2 + co-sign

Rules:

- No other member's content is shown before V2, and none during the verification flow itself.
- min_counterparty_tier (default V2, option V3) is a Stage 0 hard gate in both directions.
- Re-verification triggers: a Guardian minor signal, a change of device plus a profile-photo change, a credible report, or a 12-month expiry.

3.3 Login assurance — account holder only

v1.2, founder requirement (D-16). Only the account holder can sign in. The rules depend on the surface:

Surface	Factors required at every login	Both required?
Native app (iOS, Android) and PWA on a mobile device	B1 device-bound biometric passkey + B2 liveness face match to the account holder	Yes — two biometric factors
Desktop (web browser or installed PWA on a computer)	F1 passkey (platform authenticator with user verification, or FIDO2 security key) + F2 approval from the member's registered mobile device, which itself requires B1 (or a second registered FIDO2 security key)	Yes — two factors

Factor definitions:

- **B1 — Device biometric passkey.** A WebAuthn/FIDO2 credential bound to the device's secure element. userVerification = required and must be satisfied by **biometrics only** for login:
 - iOS: biometryCurrentSet;
 - Android: BIOMETRIC_STRONG, key invalidated on biometric enrolment change;
 - mobile PWA: platform authenticator. The biometric never leaves the device. **If anyone adds or changes a fingerprint or face on the device, the credential is invalidated** and the member must log in again with B1 re-registration + B2 (FR-059). This defeats the partner who enrolls their own fingerprint (A1).
- **B2 — Liveness face match.** A randomised challenge-response liveness check (ISO 30107-3 PAD Level 2 certified provider), matched 1:1 against the account holder's reference enrolled at V1. The reference is held by the provider under a deletion obligation, never by TRYST (D-18). Requires the explicit biometric_login consent.
- **F1 — Desktop passkey.** Windows Hello, Touch ID or a roaming FIDO2 key with PIN or biometric. Phishing-resistant, origin-bound.
- **F2 — Registered-device approval.** The desktop shows a QR code; the member scans it **in the TRYST app** on a registered mobile device and approves with B1. No push notification is sent, so nothing appears on a lock screen. Alternative: a second registered FIDO2 security key.

Never accepted as a login factor: passwords (TRYST has none), SMS or email OTP, magic links, security questions, or support-desk overrides. Contact OTP is used **only** at sign-up to prove ownership of the contact handle (V0).

Login vs unlock:

- **Login** creates a session on a device: first use on a device, after sign-out or Burn, after session expiry, after a biometric-enrolment change, or on a risk step-up.
- **Unlock** reopens the app within a live session: device biometric (or the duress PIN, which opens the decoy) per FR-027.

Session rule	Mobile (app / PWA)	Desktop
Maximum session	30 days	12 hours

Session rule	Mobile (app / PWA)	Desktop
Idle lock	2 min default (member-adjustable 1-15)	15 min → full re-login
Token binding	DPoP to the device key	DPoP to a non-extractable WebCrypto key

Step-up (repeat both factors for the surface, valid 5 min) is required to:

- add or revoke a device;
- broaden the Discretion Policy;
- change contact handle or payment method;
- co-sign or change a couple link or veto mode;
- export data;
- view the device list;
- start account recovery.

It is **never** required for Burn, Panic, report, block, subscription cancel or account deletion. Deletion requires B1 only, so it stays one step (ToS cl. 16.3, 25.1).

Before V1: a V0 member has no B2 reference, so they can only continue onboarding on the device they signed up on. Login on any other device is unavailable until V1 is complete.

Downgrade resistance: the server decides the surface from attestation (native) and from the registered authenticator's properties. It does not trust a client claim. The desktop path still requires a second, separately registered authenticator, so claiming "desktop" from a phone gains nothing.

Account recovery (lost or replaced device, FR-061):

1. B2 liveness match.
2. Fresh V2 age assurance with an ID match, whose document anchor must equal the account's stored anchor_doc (same document).
3. A 24-hour hold, cancellable from any still-registered device.
4. New passkey registration.

No staff member can bypass recovery.

4. Data model

Three isolated PostgreSQL 16 clusters with separate credentials and separate KMS domains. **No plaintext join between identity and profile.** The join key is `HMAC(identity_id, HSM_pepper_join)`, computed only inside the identity service. [A §9.2, §10]

4.1 IDENTITY-DB

```
CREATE TABLE identity (
  identity_id      UUID PRIMARY KEY,
  contact_hash     BYTEA UNIQUE NOT NULL,    -- HMAC(phone|email, HSM pepper_contact)
  contact_ct       BYTEA,                    -- encrypted under root key; for OTP/notices only
  age_assured      BOOLEAN NOT NULL DEFAULT FALSE,
  assurance_tier    TEXT CHECK (assurance_tier IN ('V0','V1','V2','V3')),
  assurance_token   TEXT,                    -- provider ref. NO ID image, NO DOB
  assurance_at      TIMESTAMPTZ,
  billing_ref       TEXT,                    -- PSP token. No PAN, ever
  jurisdiction      CHAR(2) NOT NULL,
  root_key_ref      TEXT NOT NULL,           -- KMS handle; destroy = erasure
  created_at        TIMESTAMPTZ DEFAULT now(),
  deleted_at        TIMESTAMPTZ
);

-- v1.1 addition (E-02): ban anchors can only be written at ban time if candidates exist.
-- Candidates are erased with the account unless a permanent ban copies them to BAN-DB.
CREATE TABLE anchor_candidate (
  identity_id      UUID PRIMARY KEY REFERENCES identity,
  anchor_doc        BYTEA NOT NULL,          -- HMAC(doc_number, HSM pepper_ban)
  anchor_device     BYTEA[] NOT NULL,        -- HMAC(attestation_id, pepper_ban)
  anchor_payment    BYTEA,                  -- HMAC(bsp_instrument_token, pepper_ban)
  created_at        TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE device (
  device_id        UUID PRIMARY KEY,
  identity_id       UUID NOT NULL REFERENCES identity,
  device_pubkey     BYTEA NOT NULL,          -- DPoP + MLS credential binding
  device_hash       BYTEA NOT NULL,          -- HMAC(attestation_id, pepper_device)
  platform          TEXT CHECK (platform IN ('ios','android','web')),
  surface           TEXT CHECK (surface IN ('mobile_app','mobile_pwa','desktop')), -- v1.2
  revoked_at        TIMESTAMPTZ
);

-- v1.2 addition (D-16): login authenticators. No biometric data is stored by TRYST.
CREATE TABLE authenticator (
  credential_id     BYTEA PRIMARY KEY,      -- WebAuthn credential id
  identity_id       UUID NOT NULL REFERENCES identity,
  device_id         UUID REFERENCES device, -- NULL for roaming security keys
  public_key        BYTEA NOT NULL,
  aaguid            UUID,
  kind              TEXT CHECK (kind IN ('platform_biometric','platform_uv','roaming_key')),
  bio_enrolment_bound BOOLEAN NOT NULL,     -- invalidated on biometric enrolment change
  sign_count        BIGINT DEFAULT 0,
  created_at        TIMESTAMPTZ DEFAULT now(),
  revoked_at        TIMESTAMPTZ
);

CREATE TABLE login_reference (
  identity_id       UUID PRIMARY KEY REFERENCES identity,
  provider          TEXT NOT NULL,
  reference_token    TEXT NOT NULL,          -- provider ref only; deleted at provider on erasure
  enrolled_at       TIMESTAMPTZ NOT NULL
);

CREATE TABLE auth_event (
  event_id          UUID PRIMARY KEY, identity_id UUID, device_id UUID,
  kind              TEXT,                    -- login_ok|login_fail|step_up|recovery_*|bio_change
  factors TEXT[], surface TEXT, created_at TIMESTAMPTZ DEFAULT now()
);
```

4.2 BAN-DB (separate store, separate key domain; survives erasure)

```
CREATE TABLE ban_anchor (  
  anchor_id          UUID PRIMARY KEY,  
  anchor_doc         BYTEA, anchor_device BYTEA[], anchor_payment BYTEA,  
  anchor_biometric   BYTEA,                -- NULL unless counsel confirms lawful basis (D-08)  
  reason_code        TEXT NOT NULL,         -- unsafe_ground enum; NOT free text, NOT evidence  
  tier               TEXT CHECK (tier IN ('permanent','law_enforcement_referred')),  
  reviewed_by        TEXT NOT NULL,         -- staff id; always a human decision  
  created_at         TIMESTAMPTZ DEFAULT now(),  
  expires_at         TIMESTAMPTZ,          -- NULL for permanent; destroyed on successful appeal  
  consortium_share   BOOLEAN DEFAULT FALSE  -- L5, gated on opinion (Q8)  
);
```

4.3 PROFILE-DB

```
CREATE TABLE profile (
  profile_id      UUID PRIMARY KEY,
  segment         TEXT CHECK (segment IN ('S1','S2','S3','S4','S5','S6')),
  entity_type     TEXT CHECK (entity_type IN ('solo','couple')),
  display_name    TEXT,
  pronouns        TEXT,
  gender_identity TEXT,
  seeking         TEXT[],
  modes           TEXT[],
  age_band        TEXT,
  city_geohash5   TEXT,
  bio_ct          BYTEA,
  visibility       TEXT CHECK (visibility IN ('public','matched','incognito')),
  status          TEXT DEFAULT 'active',
  version         INT NOT NULL DEFAULT 1,
  created_at      TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE couple_invite (
  invite_id      UUID PRIMARY KEY,
  inviter_profile UUID NOT NULL REFERENCES profile,
  token_hash     BYTEA NOT NULL,
  inviter_device_hash BYTEA NOT NULL,
  expires_at     TIMESTAMPTZ NOT NULL,
  consumed_at    TIMESTAMPTZ
);

CREATE TABLE couple_link (
  couple_id      UUID PRIMARY KEY,
  couple_profile UUID NOT NULL REFERENCES profile, -- the entity_type='couple' profile
  profile_a      UUID NOT NULL REFERENCES profile,
  profile_b      UUID NOT NULL REFERENCES profile,
  a_cosigned_at  TIMESTAMPTZ NOT NULL,
  b_cosigned_at  TIMESTAMPTZ NOT NULL,
  a_device_hash  BYTEA NOT NULL,
  b_device_hash  BYTEA NOT NULL,
  approved_version INT NOT NULL,
  veto_mode      TEXT DEFAULT 'either' CHECK (veto_mode IN ('either','both')),
  dissolved_at   TIMESTAMPTZ,
  CONSTRAINT distinct_devices CHECK (a_device_hash <> b_device_hash),
  CONSTRAINT distinct_members CHECK (profile_a <> profile_b)
);

CREATE TABLE intent_vector (
  profile_id      UUID PRIMARY KEY REFERENCES profile,
  intent_shape    TEXT[],
  structure       TEXT,
  desire_tags     JSONB,
  hard_limits     TEXT[] NOT NULL,
  discretion       JSONB,
  logistics        JSONB,
  min_counterparty_tier TEXT DEFAULT 'V2',
  embedding        VECTOR(128),
  private_fields  TEXT[],
  confirmed_at    TIMESTAMPTZ,
  updated_at      TIMESTAMPTZ
);

CREATE TABLE revealed_preference (
  profile_id      UUID PRIMARY KEY REFERENCES profile,
  embedding        VECTOR(256),
  alpha           REAL CHECK (alpha BETWEEN 0.15 AND 0.85),
  divergence       REAL, confidence REAL, n_signals INT,
  personalisation_enabled BOOLEAN DEFAULT TRUE,
  computed_at     TIMESTAMPTZ
);

CREATE TABLE discretion_policy (
  profile_id      UUID REFERENCES profile,
  version         INT,
  policy_ct       BYTEA NOT NULL,
  zones_geohash   TEXT[],
  created_at      TIMESTAMPTZ DEFAULT now(),
  PRIMARY KEY (profile_id, version)
);
```

```

CREATE TABLE media (
  media_id          UUID PRIMARY KEY,
  owner_profile     UUID REFERENCES profile,
  object_key        TEXT NOT NULL,          -- client-encrypted ciphertext
  tier               TEXT CHECK (tier IN ('profile_public','profile_private','thread')),
  explicit          BOOLEAN DEFAULT FALSE,   -- web surface only, V2 only
  moderation_state  TEXT DEFAULT 'pending',
  expires_at        TIMESTAMPTZ,           -- thread media: 7d default
  created_at        TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE reveal_grant (
  grant_id          UUID PRIMARY KEY,
  owner_profile     UUID, recipient_profile UUID,
  scope             TEXT,                  -- reveal_scope enum
  media_id          UUID,                  -- NULL for voice/video scope
  owner_version     INT,
  wrapped_key_ref   TEXT,                  -- destroyed on revoke
  expires_at        TIMESTAMPTZ, revoked_at TIMESTAMPTZ,
  created_at        TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE slate_item (
  slate_id          UUID, profile_id UUID, candidate_id UUID,
  score            REAL, model_version TEXT,
  explanation_codes TEXT[],               -- 2-4 non-sensitive codes
  exploration       BOOLEAN, paid_label BOOLEAN,
  created_at        TIMESTAMPTZ,
  PRIMARY KEY (slate_id, candidate_id)
);

CREATE TABLE intent (
  intent_id        UUID PRIMARY KEY,
  from_profile     UUID, to_profile UUID,
  keys_spent       INT NOT NULL DEFAULT 0,
  via_envoy_proposal UUID,               -- ENV0Y tier; always human-approved (D-04)
  state            TEXT NOT NULL,         -- intent_state enum
  created_at        TIMESTAMPTZ, delivered_at TIMESTAMPTZ
);

CREATE TABLE handshake (
  handshake_id     UUID PRIMARY KEY,
  a_profile UUID, b_profile UUID,
  transcript_ct     BYTEA,                -- encrypted agent turns, 30d TTL
  brief_a_ct BYTEA, brief_b_ct BYTEA,
  compatibility REAL, meet_probability REAL,
  a_decision TEXT, b_decision TEXT,       -- handshake_decision
  opened_thread     UUID,                 -- non-null ONLY on double accept
  created_at        TIMESTAMPTZ
);

CREATE TABLE thread (
  thread_id        UUID PRIMARY KEY,
  handshake_id     UUID,                  -- NULL in P1 control cohort
  mls_group_id     BYTEA NOT NULL,
  participant_profiles UUID[] NOT NULL,
  retention_days    INT DEFAULT 30 CHECK (retention_days IN (7,30,90)),
  safety_state      TEXT DEFAULT 'normal', -- normal|frozen|closed
  burned_at        TIMESTAMPTZ,
  created_at        TIMESTAMPTZ
);

CREATE TABLE message_envelope (
  thread_id UUID, seq BIGINT, sender_device UUID,
  ciphertext BYTEA NOT NULL, expires_at TIMESTAMPTZ NOT NULL,
  PRIMARY KEY (thread_id, seq)
);

CREATE TABLE meet (
  meet_id UUID PRIMARY KEY, thread_id UUID,
  state TEXT,
  window_start TIMESTAMPTZ, checkin_due_at TIMESTAMPTZ,
  aftercare_due_at TIMESTAMPTZ           -- +48h
);

CREATE TABLE exclusion_ring (
  profile_id UUID, excluded_profile_id UUID,

```

```

source TEXT,                                -- psi_contact|device_graph|manual|payment|geo|wifi
confidence REAL,
PRIMARY KEY (profile_id, excluded_profile_id)
); -- ALWAYS bidirectional, ALWAYS silent

CREATE TABLE consent_ledger (
  consent_id UUID PRIMARY KEY, profile_id UUID NOT NULL,
  kind TEXT NOT NULL,                      -- consent_kind enum
  granted BOOLEAN NOT NULL, scope JSONB,
  prev_hash BYTEA, entry_hash BYTEA NOT NULL, -- hash chain; append-only
  created_at TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE aftercare (
  meet_id UUID PRIMARY KEY, reporter UUID, counterparty UUID,
  occurred BOOLEAN, as_represented SMALLINT, would_repeat BOOLEAN, safety_flag BOOLEAN,
  created_at TIMESTAMPTZ
); -- NEVER surfaced to counterparty. NEVER a public rating.

```

4.4 SAFETY-DB (T&S; access only through the trust console)

```

CREATE TABLE guardian_signal (              -- scores and reason codes only; no content
  signal_id UUID PRIMARY KEY, thread_id UUID, subject_profile UUID,
  model_id TEXT, model_version TEXT, score REAL, reason_code TEXT,
  source TEXT CHECK (source IN ('on_device','server_profile','server_graph')),
  created_at TIMESTAMPTZ
);
CREATE TABLE report_case (
  case_id UUID PRIMARY KEY, reporter_pseudo BYTEA, subject_profile UUID,
  category TEXT, severity SMALLINT, disclosed_content_ref TEXT, -- reporter-disclosed only
  training_consent BOOLEAN DEFAULT FALSE, -- D4 source; never a condition of action
  state TEXT, sla_due_at TIMESTAMPTZ, legal_hold BOOLEAN DEFAULT FALSE,
  created_at TIMESTAMPTZ
);
CREATE TABLE enforcement (
  enforcement_id UUID PRIMARY KEY, subject_profile UUID,
  action TEXT, ground TEXT, reason_code TEXT,
  decided_by TEXT, -- REQUIRED for permanent (human)
  appeal_state TEXT, appeal_reviewer TEXT, created_at TIMESTAMPTZ
);
CREATE TABLE staff_access_log (             -- immutable (WORM)
  entry_id UUID PRIMARY KEY, staff_id TEXT, approver_id TEXT,
  resource TEXT, reason_code TEXT, created_at TIMESTAMPTZ
);

```

4.5 Commerce and operations (PROFILE-DB schema commerce, ops)

```

CREATE TABLE commerce.entitlement (profile_id UUID, tier TEXT, addon_ghost BOOLEAN,
  status TEXT, source TEXT CHECK (source IN ('web','voucher','app_store','play')),
  renews_at TIMESTAMPTZ, renewal_notice_sent_at TIMESTAMPTZ, PRIMARY KEY (profile_id));
CREATE TABLE commerce.keys_ledger (entry_id UUID PRIMARY KEY, profile_id UUID,
  delta INT, reason TEXT, intent_id UUID, balance_after INT, created_at TIMESTAMPTZ);
CREATE TABLE commerce.deposit (profile_id UUID PRIMARY KEY, amount_minor INT,
  state TEXT, credited_keys INT, created_at TIMESTAMPTZ);
CREATE TABLE ops.deletion_job (job_id UUID PRIMARY KEY, subject_ref BYTEA,
  systems TEXT[], started_at TIMESTAMPTZ, completed_at TIMESTAMPTZ,
  completion_proof BYTEA); -- signed record of key destruction + purges

```

5. Edge API contract (v1)

Cross-cutting middleware, in order:

1. TLS 1.3
2. OAuth2 access token **DPoP-bound** to the device key
3. Jurisdiction gate
4. Tier gate (§3.2)
5. Article 9 consent check
6. Per-endpoint rate limit
7. Idempotency (Idempotency-Key header required on all POST/PUT/DELETE)

The **Min** column is the minimum verification tier. sys means server-to-server only.

5.1 Auth, devices, assurance

Method	Path	Min	Contract
POST	/v1/auth/start	—	Sign-up only. {contact} → OTP sent. Uniform response whether or not the account exists. Never a login factor (§3.3)
POST	/v1/auth/verify	—	Sign-up only. {otp, device_pubkey, attestation} → onboarding session + device registered. Ban-anchor check runs here for new identities (03 §8)
POST	/v1/auth/passkeys/register (begin / finish)	V0	Register B1 (mobile) or F1 (desktop) WebAuthn credential; step-up required after the first one
POST	/v1/auth/login/begin	—	{contact_hint?} → WebAuthn challenge + required_factors (decided by the server, §3.3). Uniform response
POST	/v1/auth/login/passkey	—	WebAuthn assertion (B1 or F1) → login_state = factor1_ok (no session yet)
POST	/v1/auth/login/liveness	—	Mobile: start B2 provider session → provider callback (sys) → session issued only on match
POST	/v1/auth/login/cross-device	—	Desktop: → QR token (60 s); GET .../{id} polls status → session issued only on approval
POST	/v1/auth/approvals/{qr_token}	V1	Called from the registered mobile app with a fresh B1 assertion; approves or denies the desktop login
POST	/v1/auth/step-up	V0	Same factor flow as login → step-up token (5 min) for §3.3 sensitive actions
POST	/v1/auth/recovery/begin · /finish	—	B2 + fresh V2 with matching anchor_doc → 24 h hold → new passkey (FR-061)
POST	/v1/auth/refresh	V0	DPoP refresh
GET / DELETE	/v1/devices · /v1/devices/{id}	V0	List and revoke devices (step-up required , §3.3)
POST	/v1/assurance/session	V0	{kind: liveness age} → provider hand-off URL
POST	/v1/assurance/callback	sys	Signed provider token → is_adult boolean + anchor candidates. Raw document and biometric never stored
POST	/v1/attestations/conduct	V1	Conduct declaration (ToS cl. 3.5) → consent ledger. Required to complete V2

5.2 Account, consent, data rights

Method	Path	Min	Contract
GET / POST	/v1/consents	V0	Read the ledger; append grant or withdrawal (never mutate)
POST	/v1/account/pause	V0	Removed from discovery immediately
POST	/v1/account/vanish	V0	Hidden + threads closed; account kept
POST	/v1/account/export	V0	SAR/portability export (encrypted), < 30 days; target < 24 h
DELETE	/v1/account	V0	Cryptographic erasure, < 60 s p99 . Returns deletion_job_id and, later, completion_proof

5.3 Intake, profile, discretion

Method	Path	Min	Contract
POST	/v1/intake/turn	V0	Cartographer conversational turn
GET	/v1/intake/vector	V0	Proposed IntentVector (structured)
POST	/v1/intake/vector/confirm	V0	Member confirms or edits each field; stored with confirmed_at
PATCH	/v1/profile	V0	Pseudonymous fields only
POST / DELETE	/v1/profile/media · /{id}	V1	Client-encrypted blob + wrapped keys; public-tier photos go through server moderation (03 §7.5)
PUT	/v1/discretion/policy	V0	New version (§6.4). Rejects any change that broadens exposure unless confirm_broaden=true is sent from a fresh biometric/PIN session
PUT	/v1/discretion/zones	V0	Home/work exclusion geofences (geohash-6 cells)
POST	/v1/exclusion/psi/blind	V2	OPRF round 1

Method	Path	Min	Contract
POST	/v1/exclusion/psi/commit	V2	OPRF round 2 → suppression written. Nothing returned about the intersection
POST	/v1/burn	V0	Renamed from /v1/panic (E-21). Revoke device keys, sign out everywhere; the client wipes local data

5.4 Couples

Method	Path	Min	Contract
POST	/v1/couple/invite	V2	→ co-sign token (24 h)
POST	/v1/couple/cosign	V2	Must come from a device whose hash differs from the inviter's. Both partners must approve the exact profile version before publication
PUT	/v1/couple/{id}/veto-mode	VC	Change requires both partners' confirmation
DELETE	/v1/couple/{id}	V2	Either partner dissolves immediately; no reason shown to the other

5.5 Discovery and learning

Method	Path	Min	Contract
GET	/v1/slate	V2	Up to 18 cards incl. 15% exploration; each with explanation_codes (2-4) and paid_label. Re-authorised against the current Discretion Policy and block graph on every read
POST	/v1/intent	V2	{target, keys_spent} → 202 {intent_id, state}. Inbound-cap overflow returns state=sent to the sender and is queued (the cap is never revealed)
POST	/v1/pass · /v1/save	V2	Private
POST	/v1/signals:batch	V0	≤ 50 behaviour events (§8)
GET	/v1/preferences/insights	V2	Category-level view of what has been learned (never a raw vector)
POST	/v1/preferences/correction	V2	"More / less like this" and category corrections
POST	/v1/preferences/reset	V2	Neutralise RevealedPreferenceVector; α returns to 0.15; rebuild from the IntentVector
PUT	/v1/preferences/personalisation	V2	Turn personalisation on or off

5.6 Handshake, ENVOY tier, reveal

Method	Path	Min	Contract
—	(system) handshake created on mutual intent	—	Not client-callable in v1.1 (E-29)
GET	/v1/handshake/{id}/brief	V2	The caller's own asymmetric Brief only (§6.2)
POST	/v1/handshake/{id}/decision	V2	accept decline amend (+ amend fields). Thread opens only when both are accept (couples: per veto_mode)
GET	/v1/envoy/proposals	V2 + envoy	Agent-proposed intents with rationale
POST	/v1/envoy/proposals/{id}/approve	V2 + envoy	One-tap human approval required for every outbound intent (D-04)
POST	/v1/reveal-grants	V2	{recipient, scope, media_id?, expires_at}
DELETE	/v1/reveal-grants/{id}	V2	Destroys the wrapped key; access ends at once (p95 < 5 s, including CDN)

5.7 Threads (E2EE; the server relays ciphertext only)

Method	Path	Min	Contract
POST / GET	/v1/threads/{id}/messages	V2	MLS ciphertext envelopes; expires_at set from retention_days
PUT	/v1/threads/{id}/retention	V2	7 / 30 / 90 days; the shortest elected by any participant wins
POST	/v1/threads/{id}/meet	V2	propose confirm cancel
POST	/v1/threads/{id}/checkin	V2	Safe Meet check-in; a missed check-in triggers silent escalation to the trusted contact

Method	Path	Min	Contract
POST	/v1/threads/{id}/burn	V2	Revoke keys on both sides; thread closed
POST	/v1/aftercare/{meet_id}	V2	Private outcome (48 h after the meet)

5.8 Safety

Method	Path	Min	Contract
POST	/v1/report	V0	{subject, category, disclosed_content?, training_consent?} → SLA routing. The reporter is never revealed
POST	/v1/block	V0	Bidirectional and immediate; removes thread access
POST	/v1/guardian/signals	V2	On-device scores: {thread_id, model_id, version, score, reason_code}. Never content
POST	/v1/safety/panic	V0	Emergency. Live location + preserved evidence → emergency escalation. Overrides TTLs (P7)
POST	/v1/safety/share-plan	V2	Encrypted, unbranded, auto-deleting plan for a trusted contact
POST	/v1/appeals	V0	Appeal an enforcement action; a different reviewer decides within 10 working days
POST	/v1/attestations/dbs	V2	Self-submitted Basic DBS through the issuing route; shown as a dated fact (P3)

5.9 Commerce (web-first)

Method	Path	Min	Contract
GET	/v1/entitlements	V0	Tier, add-ons, Keys balance, renewal date
POST	/v1/deposit	V1	£9.99 refundable deposit → Keys credit
POST	/v1/keys/purchase	V1	Keys packs
POST	/v1/vouchers/redeem	V0	Offline voucher/gift code
POST	/v1/subscription	V1	Neutral, truthful descriptor enforced at the PSP; pre-contract and cooling-off notices
POST	/v1/subscription/cancel	V0	One step; no retention flow

5.10 Error model

RFC 9457 application/problem+json with a stable code.

- **Existence must not leak.** Anything not visible to the caller, for any reason (block, ExclusionRing, policy, jurisdiction of the target), returns the same 404 not_found.

HTTP	code	Meaning
401	auth_required, dpop_invalid, second_factor_required (+factor), step_up_required, authenticator_invalidated (biometric enrolment changed)	
403	tier_required (+required_tier), consent_required (+consent_kind), jurisdiction_blocked, entitlement_required	
404	not_found	Uniform for invisible resources
409	idempotency_conflict, version_conflict	
402	keys_insufficient	
422	validation_failed, broadening_requires_confirmation, same_device_cosign	
429	rate_limited (+retry_after)	

6. Agent and policy schemas

6.1 Envoy negotiation turn (internal bus; Protobuf mirror)

Six dimensions only: intent alignment, structure alignment, boundary intersection, logistics feasibility, discretion compatibility, verification parity. [A §5.4]

```
{
  "turn": 3,
  "from": "envoy:usr_7f3a",
  "to": "envoy:usr_91bc",
  "assert": {
    "intent_shape": "one_off",
    "structure": "attached_undisclosed",
    "notice_required_hours": 48,
    "availability": [{"dow": [2,3], "start": "18:00", "end": "23:00", "tz": "Europe/London"}],
    "travel_radius_km": 25,
    "hard_limits": ["no_photos_exchanged", "no_home_visit", "no_overnight"],
    "verification_tier": "V2",
    "min_counterparty_tier": "V2"
  },
  "query": ["intent_shape", "notice_required_hours", "hosting_capability"],
  "private_fields": ["exclusion_zones"]
}
```

Rules:

- No free-text fields.
- `private_fields` are computable but **never** appear in any output.
- Counterparty turns are untrusted data.
- At most 6 turns per handshake.
- The transcript is encrypted with a 30-day TTL.

6.2 Brief (caller-specific, asymmetric)

```
{
  "label": "agent_generated",
  "compatibility": 0.81,
  "aligned": ["intent_shape", "availability", "travel_radius", "verification"],
  "friction": [{"field": "hosting", "detail_code": "neither_can_host",
    "suggested_resolution": "hotel_or_venue"}],
  "blocking": [],
  "recommended_next": "open_thread",
  "estimated_meet_probability": 0.34
}
```

`detail_code` values map to localised copy on the client. A Brief never contains anything the counterparty marked private, nor any hard limit the counterparty has not chosen to disclose.

6.3 IntentVector (wire view)

The fields follow `intent_vector` (§4.3). `desire_tags` uses `yes|curious|no`. `hard_limits` is drawn from a controlled vocabulary (`contracts/vocab/hard_limits.yaml`). Free-text goals entered during intake are converted by Cartographer into controlled values, and the member confirms them.

6.4 Discretion Policy (versioned)

```
{
  "version": 7,
  "visibility": "incognito",
  "distance_band_km": 10,
  "zones": {"home": ["gcpvj0"], "work": ["gcpvux"]},
  "zone_behaviour": "hide_profile_while_inside",
  "reveal_rules": {"default_scope": "blurred_gallery", "require_mutual_handshake": true,
    "max_grant_hours": 72},
  "notifications": {"enabled": false, "text": "1 update"},
  "device_risk": "high",
  "min_counterparty_tier": "V2",
  "retention": {"messages_days": 30, "media_days": 7}
}
```

Monotonic safety: Curtain may tighten any field automatically. Broadening needs an explicit member action, a fresh local authentication and a new version. Every read path evaluates (`requester`, `resource`, `reveal_grant`, `block graph`, `ExclusionRing`, `discretion version`, `safety_state`, `jurisdiction`) — ABAC [B §9].

7. Retention and erasure

This table is canonical; 03 and 04 implement it, and the ToS (cl. 15) and Privacy Notice must match it.

Data	Default	Member options	Mechanism
Messages	30 d	7 / 90 d	Envelope expires_at; the client purges its copy too
Thread media	7 d	— (GHOST: shorter)	Per-object key destroyed at expiry
Profile media	Until removed	—	Per-object key; removal destroys it
Handshake transcripts	30 d	—	Encrypted; TTL
Behaviour events (raw)	180 d → aggregated features	Reset / opt-out	ClickHouse TTL
Aftercare	365 d, pseudonymous	—	
Logs	90 d, IP truncated at ingest	—	
Consent ledger	Life of account + statutory period	Export	Hash chain
Ban anchors	Permanent (or until a successful appeal)	Appeal	Declared exception (ToS cl. 15.3)
Evidence under legal hold	Duration of hold	—	Declared exception (ToS cl. 17.4); narrowly scoped
Panic-preserved location/evidence	As required by emergency services	—	Declared exception (ToS cl. 20; P7)
B2 login face reference (v1.2)	Life of account; held by the provider, not TRYST	—	Deleted at the provider on erasure; deletion receipt included in completion_proof
Auth events	90 d, IP truncated	—	TTL

Account deletion:

1. Destroy the root key in KMS.
2. Remove from discovery immediately.
3. Purge primaries.
4. Ciphertext in backups becomes undecryptable.
5. Issue a signed completion_proof.

Target < 60 s p99 (NFR-01).

8. Event taxonomy

Events go to Redpanda with schema-registry enforcement, are pseudonymous at rest, and are batched from clients through /v1/signals:batch. [A §6.1] **No message content, ever.**

Class	Events
Attention	card_impression, dwell_ms, photo_index_viewed, bio_scroll_depth, profile_revisit, expand_tag
Decision	intent_sent, pass, save, undo, hesitation_ms
Conversation	msg_sent, reply_latency_s, msg_len_bucket, typing_abandoned, question_ratio, thread_decay — computed on device from metadata
Handshake	brief_viewed, brief_accepted, friction_dismissed, amend_requested
Resolution	logistics_agreed, meet_scheduled, meet_confirmed, no_show, aftercare_score
Discretion	burn_invoked, session_aborted, geofence_hit, screenshot_detected, decoy_opened
Negative	report, block, unmatched, ghost_detected, refund_request

Envelope: {event_id, pseudo_subject, type, ts, context:{surface, app_version}, consent_basis, ttl}. The pseudo-subject rotates per training window (03 §4).

9. Couple and group semantics

- **Veto:** veto_mode=either means either partner can decline and a decline is final. both means both partners must accept before the couple's intent or handshake decision counts.
- **THIRD:** a couple(S3) ↔ solo(S4) handshake involves both partners' Envoy contexts. The solo's veto is always respected. The thread is an MLS group of 3 members.
- **QUAD:** couple ↔ couple; 4 MLS members. A thread opens only when both couples' veto rules are satisfied.
- **Leaving:** any participant can leave a group thread privately. The thread then closes for that member, and others see a neutral notice.
- **Dissolution:** immediately hides the couple profile, closes its threads and keeps both individual accounts.

10. Requirement catalogue

Owner: BE backend, FE frontend (native + web), Both. **Phase:** first phase in which the requirement must be met (01 §12). **Src:** A/B/C plus section.

10.1 Functional requirements

ID	Requirement	Owner	Phase	Src
FR-001	Discovery, intents, Envoy, threads, media and meets are locked below V2; nothing from other members is shown during verification	Both	P1	A §8.1, B FR-001, E-01
FR-002	Pseudonymous identity: no legal name, employer or exact address is ever required or shown	Both	P1	A §14.2, B FR-002
FR-003	Cartographer conversational intake produces an IntentVector; the member confirms every structured field; re-run quarterly or on drift	Both	P1	A §5.1, B
FR-004	A member can enable several modes, each with its own visibility and filters	Both	P1	B FR-003
FR-005	Versioned Discretion Policy enforced on every read path; cannot be broadened silently	BE	P1	B FR-004
FR-006	Couple profile requires VC: both at V2, distinct devices, 24 h invite, both approve the exact profile version	Both	P1	A §8.1, B FR-005
FR-007	Either partner can dissolve a couple immediately, with no reason shown to the other	Both	P1	Part B cl. 7.1
FR-008	Reveal ladder (alias → blurred → photo set → voice → video); each grant records recipient, scope, version and expiry, and is revocable	Both	P1	B FR-006
FR-009	Incognito members are discoverable only after their own outbound intent	BE	P1	B FR-007
FR-010	ExclusionRing PSI: on-device blinding; the server never learns contacts; suppression is bidirectional and silent	Both	P2	A §9.3, B FR-008
FR-011	Home/work exclusion zones suppress both sides and hide the profile while inside them	Both	P1	A §5.5, §9.4
FR-012	Daily slate of up to 18 cards with a 15% exploration floor	Both	P1	A §4, §7
FR-013	Intent costing: free tier 3/week; Keys 5 (solo→solo) / 15 (couple→solo); refund on reply; inbound cap default 12/24 h (adjustable 4-40), overflow queued and re-scored	BE	P1	A §7.4, §15.2
FR-014	Hard limits, zones, structure compatibility, ExclusionRing, blocks, tier parity and jurisdiction are Stage 0 pre-retrieval gates; any violation is a P0 incident; enforced by property tests	BE	P1	A §6.2, §7
FR-015	Handshake on mutual intent: six-dimension Envoy negotiation; asymmetric Briefs; private fields never emitted; Briefs labelled	Both	P2	A §5.4
FR-016	A thread opens only on double human accept (P2+); in P1 the control cohort opens on mutual intent	Both	P1	A §4, §17
FR-017	E2EE messaging (MLS, RFC 9420); the server stores ciphertext only and cannot read content	Both	P1	A §9.2
FR-018	Thread media is client-encrypted with a per-object key wrapped per recipient; revocation destroys the wrapped key	Both	P1	A §9.2
FR-019	Thread burn revokes keys on both sides and closes the thread	Both	P1	A §11

ID	Requirement	Owner	Phase	Src
FR-020	Meet propose/confirm/cancel; Safe Meet checklist (public venue first); check-in timer with silent escalation	Both	P1	A §19.7
FR-021	Share My Plan: encrypted, unbranded, auto-deleting share with a trusted contact	Both	P1	A §19.7
FR-022	Panic: escalation to 999 with live location and preserved evidence; a separate control from Burn	Both	P1	A §19.7, E-21
FR-023	Private Aftercare prompt 48 h after a meet; never visible to the counterparty	Both	P1	A §5.7
FR-024	Preference transparency: view learned categories, correct, disable personalisation, reset learning	Both	P2	B FR-010
FR-025	Each slate card shows 2–4 non-sensitive reasons and a correction control	Both	P2	B §6.2
FR-026	Notifications off by default; if on, content-free ("1 update") — never a name, image or excerpt	FE	P1	A §9.4, B FR-013
FR-027	Decoy skin (neutral icon/name) and silent duress PIN opening a populated innocuous state (native)	FE	P1	A §9.4
FR-028	Burn: wipe local storage, revoke device keys, sign out everywhere; confirmable in < 2 s	Both	P1	A §9.4
FR-029	Quick exit hides content and clears the client view in < 500 ms on all surfaces	FE	P1	B FR-011
FR-030	Screenshot protection (FLAG_SECURE) or detection with counterparty notice (iOS); obscured app switcher; no cloud backup; keys in Secure Enclave/StrongBox	FE	P1	A §9.4
FR-031	Entering a blocked jurisdiction auto-locks to the decoy and hides the profile	Both	P1	A §9.4, §14.5
FR-032	Report and block from every surface; the reporter is never revealed; reporters may disclose decrypted content and separately opt in to training use	Both	P1	A §21.3, Part B cl. 19
FR-033	Guardian M6a-M6e run on device for E2EE threads and send only score + reason code	Both	P1	A §21.6
FR-034	Escalation matrix routing and SLAs (03 §7.3)	BE	P1	A §8.4
FR-035	Enforcement ladder; permanent actions need a named human; appeal to a different reviewer within 10 working days	BE	P1	A §19.6
FR-036	Ban anchors are checked before account creation; a match is silently refused	BE	P1	A §19.3 L2
FR-037	No commercial sex: solicitation and payment patterns go to review; no payments between members	Both	P1	A §8.4, B FR-015
FR-038	Account deletion = cryptographic erasure < 60 s; immediate discovery removal; signed completion proof	Both	P1	A §9.2, B FR-012
FR-039	DSRs: SAR export including the consent ledger, rectification, portability	Both	P1	A §14.2
FR-040	Hash-chained consent ledger; Article 9 consent separate from the ToS accept	BE	P1	A §8.2
FR-041	Web-first billing: TRYST+ and Keys (P1), DUO, ENVOY and GHOST (P3); neutral truthful descriptor; vouchers; one-step cancel; pre-renewal and cooling-off notices	Both	P1	A §14.4, §15
FR-042	£9.99 refundable verification deposit credited as Keys	Both	P1	A §15.2
FR-043	Jurisdiction gate at the edge and at sign-up	BE	P1	A §14.5
FR-044	Conduct attestation at V2, logged separately	Both	P1	A §19.3 L3
FR-045	Basic DBS self-submission shown as a dated fact; Clare's Law explainer before the first meet (outcome never requested or stored)	Both	P3	A §19.3 L3
FR-046	Pause and vanish	Both	P1	B §3
FR-047	Profile-photo protection: EXIF strip, face-blur default, AI-generation and reverse-image checks on every upload, adversarial perturbation on public-tier photos	Both	P1	A §9.1 A8, §19.4

ID	Requirement	Owner	Phase	Src
FR-048	ENVOY tier: agent-proposed outreach, each intent approved by the human with one tap	Both	P3	A §15.2, D-04
FR-049	Couple veto_mode (either/both); THIRD and QUAD matching and MLS group threads	Both	P1	A §3, §10
FR-050	Exposure-fairness monitor (M9) adjusts the fairness penalty when inbound Gini > 0.55 per city/segment	BE	P1	A §7.4
FR-051	Native store builds are sanitised (no explicit media or copy); explicit media lives only on web behind V2	FE	P1	A §14.3
FR-052	Semi-annual transparency report: removals by ground, appeals, overturn rate, disclosures	BE	P3	A §19.6, Part B cl. 18.3
FR-053	Travel mode: set a planned location for discovery (premium)	Both	P3	A §15.2
FR-054	In-product safety notice at intake and before a first meet (04 §7)	FE	P1	A §20.3
FR-055	Envoy and other agents never send messages to a human as the member	BE	P2	A §5.4
FR-056	Passkey-only authentication: no passwords; SMS/email OTP, magic links and support overrides are never login factors (contact OTP only at sign-up)	Both	P1	D-16
FR-057	Native app and mobile PWA login requires two biometric factors: B1 device-bound biometric passkey and B2 liveness face match to the account holder (§3.3)	Both	P1	D-16
FR-058	Desktop login (browser or desktop PWA) requires two factors: F1 passkey and F2 approval from a registered mobile device via B1 (or a second FIDO2 key) (§3.3)	Both	P1	D-16
FR-059	A change to the device's biometric enrolment invalidates its passkey and forces a full login (B1 re-registration + B2)	Both	P1	D-16
FR-060	Step-up re-authentication for sensitive actions (§3.3); never for Burn, Panic, report, block, cancel or deletion	Both	P1	D-16
FR-061	Account recovery needs B2 + fresh V2 matching the stored document anchor + 24 h hold cancellable from registered devices; no staff bypass	Both	P1	D-16
FR-062	Session limits: mobile 30 d max with biometric unlock and 2 min idle lock; desktop 12 h max, 15 min idle → full login	Both	P1	D-16
FR-063	Brand: logo used exactly as supplied and palette tokens applied on every branded surface; logo never shown in decoy mode, on lock screens, in notifications, app-switcher snapshots, descriptors or Share My Plan	FE	P1	D-19

10.2 Non-functional requirements

ID	Requirement	Owner
NFR-01	Erasure < 60 s p99	BE
NFR-02	Retrieval < 40 ms p95; ranking < 120 ms p95 for 200 candidates; /v1/slate < 400 ms p95	BE
NFR-03	On-device Guardian inline < 80 ms p95 per thread turn	FE
NFR-04	Quick exit < 500 ms; Burn confirmable < 2 s; reveal revocation effective < 5 s p95	Both
NFR-05	Availability: core API 99.9%; message relay 99.95%	BE
NFR-06	UK/EU residency; primary AWS eu-west-2	BE
NFR-07	WCAG 2.2 AA (web), platform accessibility APIs (native)	FE
NFR-08	OWASP ASVS L3 (API), MASVS L2 + R (mobile); quarterly pen test; annual red team on A4/A7	Both
NFR-09	No third-party analytics, advertising or attribution SDKs in any client	FE
NFR-10	Zero standing production access; break-glass needs dual authorisation and writes an immutable log	BE

ID	Requirement	Owner
NFR-11	Logs kept 90 d, IP truncated at ingest	BE
NFR-12	Scale: P3 25k verified; P4 150k; design headroom 500k verified / 50k concurrent	BE
NFR-13	RPO $\leq$ 5 min, RTO $\leq$ 1 h; backups stay under per-member keys	BE
NFR-14	Localisation: EN-GB/EN-IE at P1; NL, DE, SV, DA, ES, PT at P4 (Guardian per-language evaluation)	Both
NFR-15	Platforms: iOS 17+, Android 10+ (StrongBox where present), evergreen browsers (last 2 versions)	FE
NFR-16	Login completion p95: mobile < 20 s including liveness; desktop < 30 s including cross-device approval	Both
NFR-17	B2 provider: ISO/IEC 30107-3 PAD Level 2 certified; face-match FAR $\leq$ 1:10,000 at FRR $\leq$ 3%; fairness across demographic groups reported by the provider and audited (D-17)	BE

03 — TRYST Backend Specification v1.1

Part of the TRYST v1.1 baseline. Implements the contracts in 02. Product intent is in 01.

1. Scope

This document covers server-side services, agents, ML, data stores, cryptography (server side), trust and safety tooling, commerce, compliance machinery and operations. Everything a client can see or call is defined in 02. This document does not redefine those contracts.

2. Service topology and stack

2.1 Stack

Source: A §12

Layer	Choice	Rationale
Edge API	Go, gRPC-gateway (REST/JSON out, gRPC in)	Concurrency, small attack surface, fast cold start
Agents	Python, FastAPI, typed state machines (LangGraph-style)	Deterministic orchestration; every agent turn can be replayed for evals
LLM, profile-touching	Self-hosted open-weight models, UK region, vLLM	Article 9 data must not leave the region or reach a third-party API. Non-negotiable
LLM, generic copy	Hosted frontier model, PII redacted at the boundary	Only where no personal data is involved
Primary stores	PostgreSQL 16 + pgvector — identity, profile, safety and ban clusters isolated	Identity split enforced in the infrastructure
Vector search	Qdrant	Filtered ANN after hard-gate pre-filtering
Events	Redpanda + Schema Registry (Protobuf)	Kafka API, lower ops burden
Analytics	ClickHouse	Behavioural aggregation; raw events purged at 180 d
Feature store	Feast	Train/serve parity (M3/M4)
Objects	S3-compatible; client-side encrypted	The server never holds plaintext media
Keys	AWS KMS + CloudHSM	Destroying the root key is the erasure primitive; peppers held in the HSM
E2EE	MLS (RFC 9420) via OpenMLS (delivery service + key packages)	Standardised; group threads for couples
Age assurance	Two providers behind one interface	Ofcom expects layered protection and due diligence; one provider is a single point of failure
Region	AWS eu-west-2 (London), UK/EU residency only	
IaC / CI / CD	Terraform, GitHub Actions, Argo CD	Auditable change control

2.2 Deployables

Source A requires each agent to be independently deployable. Core domain services start as a **modular monolith** with hard module boundaries, to fit a 2-person backend team, and are split when load or team size justifies it (D-09).

Deployable	Language	Owns	Store
edge-gateway	Go	AuthN (OAuth2 + DPoP), jurisdiction gate, tier gate, consent gate, rate limits, idempotency	Redis
identity-svc	Go	Identity, devices, authenticators and login/step-up/recovery flows (§6.7) , assurance adapters, anchor candidates, ban-anchor check, join-key HMAC, root keys	IDENTITY-DB, BAN-DB, KMS/HSM
core-svc (modular monolith)	Go	Modules: profile, couple, intent, discretion, discovery-api, reveal, threads (MLS delivery service), meet, consent, deletion, commerce	PROFILE-DB

Deployable	Language	Owns	Store
agent-cartographer, agent-mirror, agent-broker, agent-envoy, agent-curtain, agent-guardian, agent-aftercare	Python	One agent each (§3)	Own schemas / Feast / Qdrant
llm-gateway	Python	vLLM pool, prompt/policy registry, PII redaction, injection filters	—
media-svc	Go	Pre-signed upload/download, ciphertext lifecycle, public-tier moderation, perturbation	Object store
safety-svc	Go	Report intake, SLA routing, case management, enforcement, appeals, transparency data	SAFETY-DB
trust-console	Web (internal)	Moderator UI; redacted by default; break-glass flows	via safety-svc
jobs	Go	TTL purges, deletion orchestration, renewal notices, aftercare scheduling, Privacy Auditor probes	—

Bus. Agents communicate over typed Protobuf messages on Redpanda topics (agent.*), never with free text [A §5]. Synchronous calls between agents use gRPC with mTLS and SPIFFE identities.

2.3 Request path (slate)

edge-gateway (DPoP, tier $\geq$ V2, jurisdiction, consent) $\rightarrow$ core-svc/discovery-api $\rightarrow$ agent-broker:

- Stage 0 gates
- Qdrant retrieval
- M3/M4 ranking
- constraints

$\rightarrow$ agent-curtain exposure check $\rightarrow$ re-authorisation against the current Discretion Policy and block graph $\rightarrow$ response. Cached slates are **re-authorised on read** [B §8.2].

3. Agent services

Every agent has a policy file (policies/<agent>.yaml), a tool allow-list, a memory scope, a 400-case golden eval set, and an injection red-team suite (§9). [A §5, §13]

Agent	Inputs	Writes	Tools	Hard constraints
Cartographer	Intake turns	Proposed IntentVector (unconfirmed)	llm-gateway (self-hosted), tag vocabulary	Structured output only; the member confirms each field (FR-003); re-runs quarterly or when Mirror reports drift
Mirror	Behaviour events, aftercare	RevealedPreferenceVector (sole writer), α , divergence	Feast, training pipeline	Message content excluded; personalisation off $\rightarrow$ α frozen at 0.15 and no updates; reset supported (FR-024)
Broker	Effective vectors, gates, fairness state	Slates, slate_item	Qdrant, M2/M3/M4/M9	Stage 0 gates are not scored and cannot be bypassed; paid labels only within the eligible set; no gender-based uplift
Envoy	Both IntentVectors (incl. private fields), Discretion Policies, tiers	Handshake transcript, two Briefs; ENVOY-tier proposals	Rules engine + small model for friction ranking; llm-gateway only to render Brief copy from codes	Six dimensions; $\leq$ 6 turns; no free text; private fields never emitted; never messages a human; cannot open a thread (FR-015, FR-055)
Curtain	Session context, geofence hits, device risk, discretion events	Policy tightening, suppressions, nudges	M8, zone matcher	May only tighten policy; broadening needs a member action (02 §6.4)
Guardian	On-device scores, profile/media uploads, reports, graph	Signals, freezes, holds, case escalation	M6a-e, M7, M7b, hash lists	Veto over all agents; no permanent action without a human; never reads message content server-side (§7)

Agent	Inputs	Writes	Tools	Hard constraints
Aftercare	Meet events	Aftercare records → reward	Scheduler	Never visible to the counterparty; never aggregated into a public rating

3.1 Envoy negotiation algorithm

1. **Trigger:** on mutual intent (P2+), core-svc/intent publishes agent.handshake.requested.
2. **Load both sides** inside Envoy's memory scope. Private fields stay inside it.
3. **Score each dimension deterministically:**
4. *intent*: shape compatibility matrix.
5. *structure*: segment pair, veto mode, partner participation.
6. *boundaries*: set intersection of hard limits and desire tags; any no × yes collision is **blocking**.
7. *logistics*: overlap of availability windows (tz-aware), intersection of travel radii, notice, hosting.
8. *discretion*: zone intersection (must be empty), reveal pace, device risk.
9. *verification*: both sides' min_counterparty_tier satisfied.
10. **Up to 6 turns** in schema form to settle open queries (02 §6.1). Unknown fields → friction.
11. **Emit asymmetric Briefs** (02 §6.2) built from codes; llm-gateway renders only localised copy for codes, with no counterparty free text.
12. **Encrypt** the transcript and both Briefs (30 d TTL). Publish agent.handshake.completed.
13. **Guardian** may veto at any step (blocking: ["safety_hold"], no detail disclosed).

ENVOY tier: Envoy generates envoy_proposal items (candidate + rationale codes). An intent exists **only** after POST /v1/envoy/proposals/{id}/approve (D-04).

4. Behaviour learning (Mirror)

4.1 Vectors

Source: A §6.2

```
IntentVector          stated    dim 128   source Cartographer  updated quarterly / on confirm
RevealedPreferenceVector revealed dim 256   source Mirror        nightly batch + hourly delta
DivergenceScore = 1 - cosine(project(IntentVector), RevealedPreferenceVector)
EffectiveVector = α · Revealed + (1 - α) · project(Intent)
α = σ(w · [interaction_count, days_active, divergence_stability, aftercare_count]), α ∈ [0.15, 0.85]
```

- Divergence is used as a signal, not corrected away.
- The 0.15 floor on stated preference is a **product rule** (P5) and is enforced as a constraint, not left to the optimiser.

4.2 Privacy constraints

- **Inputs:** only events in 02 §8. **No message content.** Conversation features are computed on device from metadata.
- **Pseudonyms:** pseudo-subject IDs rotate every training window. Deleted members are dropped from serving immediately and from the next training run.
- **Raw events:** kept 180 d, then aggregated features only. Cohort reporting needs $k \geq 50$.
- **Excluded from training:** protected or sensitive characteristics are never targets or inferred labels. Orientation, kinks and structure are used only as filters or features the member chose.

4.3 Model inventory

Source: A §6.3, §19.3, §21

ID	Model	Type	Serving	Target
M1	Intent classifier	Multi-label transformer, 9 classes	Batch + on edit	Macro F1 > 0.82
M2	Two-tower retrieval	Dual encoder, 256-d, ANN	< 40 ms p95	Recall@200 > 0.91
M3	Cross-encoder ranker	GBDT + neural blend	< 120 ms p95 / 200 candidates	Mutual-reply AUC > 0.78
M4	Meet propensity	Survival (time-to-meet)	Nightly	C-index > 0.70

ID	Model	Type	Serving	Target
M5	No-show / flake risk	GBDT on on-device conversation features	Pre-meet	Precision@20% > 0.55
M6a-e	Guardian behavioural family	\$7	On device (+ server graph)	\$7.6
M7	Authenticity (bot/catfish)	Ensemble: image, text, device, graph	Sign-up + continuous	Catch rate > 0.93
M7b	Ban-evasion graph	Style similarity, device/network adjacency	Server	Human review before any anchor extension
M8	Discretion risk	Contextual bandit	Per session	Reduction in Burn invocations
M9	Exposure fairness monitor	Gini + constraint solver	Hourly	Inbound Gini < 0.55

4.4 Reward

Source: A §6.4

```
R = 0.10·mutual_reply + 0.15·sustained_thread(≥6 turns, both sides) + 0.20·logistics_agreed
+ 0.35·meet_confirmed + 0.25·aftercare_positive
- 0.40·report - 0.20·block - 0.15·no_show - 0.10·ghost_after_intent
- 0.05·session_time_beyond_8min
```

Time in app is a **cost**. A model that improves AUC but lowers ΔR or the meet rate is rejected (§9).

4.5 Cold start and exploration

- **Turns 1-20:** content-based from the IntentVector; $\alpha = 0.15$.
- **Exploration:** a permanent 15% of every slate, chosen by Thompson sampling.
- **New-profile boost:** 72 h decaying multiplier, capped by the inbound limiter.
- **Couples:** a blended vector from both partners plus a learned `joint_veto_model`. The true preference is the **intersection** of the two partners', not the union.

5. Matching and ranking (Broker)

5.1 Pipeline

Source: A §7

```
STAGE 0  HARD GATES (non-scored, non-bypassable, bidirectional)
| verification tier ≥ V2 and ≥ each side's min_counterparty_tier
| hard-limit intersection: zero collisions
| structure compatibility matrix (02 §2.3) and couple VC validity
| ExclusionRing (PSI + heuristics)
| geofence exclusion zones (both sides)
| block graph / report holds / safety_state
| jurisdiction gate
| visibility (incognito: only if caller already received their intent)
STAGE 1  RETRIEVAL (M2)           ~50k → 200      < 40 ms
STAGE 2  RANKING (M3 + M4)        200 → 40         < 120 ms
STAGE 3  CONSTRAINTS              exposure fairness, inbound caps, diversity, paid labels
STAGE 4  SLATE                    ≤ 18 cards incl. 15% exploration, 2-4 explanation codes each
```

5.2 Launch baseline (P1, before M2/M3 are trained)

Source B's transparent weighted score is the **P1 ranker** and later the fallback:

```
score = 0.24·reciprocal_attraction + 0.20·intent_fit + 0.15·discretion_fit
+ 0.12·communication_fit + 0.10·availability_logistics + 0.08·reliability
+ 0.06·novelty + 0.05·model_confidence - risk_penalties
```

5.3 Multi-person scoring (THIRD/QUAD)

Edge scores are computed for every required pairing. The entity score is a **max-min** (soft-min with $\tau \approx 0.1$ for differentiability) over required edges, so one person's strong interest cannot mask another participant's poor fit [B

§6.2]. Each couple's veto rules (02 §9) and the solo's veto apply on top.

5.4 Exposure fairness

1. **Inbound cap:** 12 intents per 24 h by default (member-adjustable 4–40). Overflow is queued and re-scored, never delivered in a burst, and the cap is never revealed to the sender.
2. **Gini constraint:** M9 runs hourly per city and segment. If Gini > 0.55, the ranker's fairness penalty rises until it recovers. Fairness is a constraint, not the objective.
3. **Asymmetric outreach cost:** couple→solo costs 3× the Keys (15 vs 5), fully refunded on reply.

S4 inbound above the cap is a release-blocking regression (§9).

5.5 Hard-limit inviolability

Stage 0 is implemented as a pure function with **property-based tests**: for random entities and constraint sets, no output may violate a gate. These tests run on every PR touching broker/ or contracts/. A failing case is a P0 incident, even in staging [A §6.2].

6. Security, cryptography and discretion (server side)

6.1 Threat model

Source: A §9.1

ID	Adversary	Likelihood	Primary server-side controls
A1	Partner with physical access to the device	Very high	Device revocation, Burn endpoint, session TTLs, masked push payloads (no content in APNs/FCM)
A2	Partner reading a shared bank statement	Very high	Neutral truthful descriptor, voucher path, 7-day pre-renewal notice
A3	Recognition through the shared social graph	High	ExclusionRing PSI + heuristics, progressive reveal, perturbation, geofence
A4	Mass data breach	Medium / existential	E2EE, client-side media encryption, identity/profile split, cryptographic erasure, short TTLs
A5	Targeted extortion by a counterparty	Medium	Watermarked media, screenshot signals, M6e freeze, evidence preservation
A6	Civil discovery in divorce proceedings	Medium	Minimal retention, erasure, published legal-process policy, transparency report
A7	Insider	Medium	Zero standing access, dual-authorised break-glass, WORM audit, no content access by design
A8	Face-search de-anonymisation	Medium, rising	Adversarial perturbation on public-tier photos; private photos never served unencrypted

6.2 Cryptographic design

Source: A §9.2

- **Messaging:** MLS (RFC 9420). The server is the Delivery Service and Authentication Service: it stores key packages and ciphertext only. It **cannot** read content.
- **Media:** the client generates a per-media AES-256-GCM key; ciphertext goes to the object store; the key is wrapped per recipient and delivered in band. **Revoke = destroy the wrapped key.**
- **Identity split:** IDENTITY-DB and PROFILE-DB use separate credentials and KMS domains. The join key is $\text{HMAC}(\text{identity_id}, \text{pepper_join})$, computed in identity-svc from an HSM-held pepper. Neither dump alone identifies anyone.
- **Peppers** (contact, join, device, ban) are HSM-resident and non-exportable, with yearly rotation and dual-run.
- **Field encryption:** sensitive PROFILE-DB columns (bio_ct, policy_ct, zones, transcripts, Briefs) use envelope encryption under the **member's data key**, which is derived from the member's root key in KMS.

6.3 Erasure (< 60 s p99)

DELETE /v1/account RUNS deletion_job:

1. Mark the profile deleted and remove it from Qdrant and slates **synchronously**.
2. Revoke all devices and tokens.

3. **Destroy the root key** (KMS schedule-deletion with the minimum window, plus immediate disable; the HSM-wrapped data key is zeroised).
4. Delete rows and object keys (best effort; they are already undecryptable).
5. Drop features from Feast online and mark the pseudo-subject for training exclusion.
6. If no ban applies, delete `anchor_candidate`. Revoke all authenticators and request deletion of the provider-held B2 login reference; the provider's deletion receipt is attached to the proof (it may arrive after the 60 s on-platform erasure).
7. Write a signed `completion_proof` (key-destruction receipt + purge summary).

Exceptions (02 §7): ban anchors, legal hold, Panic preservation. Each is written to the job record.

6.4 ExclusionRing PSI (server half)

Source: A §9.3

- OPRF over ristretto255 (RFC 9497). The server key `k` lives in the HSM.
- Round 1: the server evaluates blinded points.
- Round 2: the client uploads unblinded PRF outputs. The server intersects them with the member-identifier PRF set (each member's own contact hash, PRF-evaluated at enrolment) and writes **bidirectional** `exclusion_ring` rows.
- The server **returns nothing** about the intersection, and stores no uploaded PRF outputs beyond the intersection computation.
- Rate-limit enrolment (contacts $\leq 5,000$ per call; ≤ 4 calls per day) to block membership-oracle attacks.
- **Heuristic suppression** (suppress only, never notify): shared payment fingerprint, sustained shared home geohash, device-graph adjacency, shared Wi-Fi BSSID history (only where the client opts in).

6.5 Authorisation (ABAC)

Every read evaluates (`requester`, `resource`, `reveal_grant`, `block graph`, `ExclusionRing`, `discretion version`, `safety_state`, `jurisdiction`, `tier`) in a central policy engine (OPA/Cedar) shared by all `core-svc` modules [B §9]. Denials are indistinguishable from not-found (02 §5.10). Policy tests are generated per read path; the Privacy Auditor runs them continuously against staging and production canaries.

6.6 Engineering non-negotiables

Source: A §12

- No third-party analytics, advertising or attribution SDK (server or client); NFR-09.
- Zero standing production data access; break-glass needs dual authorisation and writes `staff_access_log` (WORM); NFR-10.
- Staff cannot read message content; this is an architectural property.
- Quarterly external pen test; annual red team scoped to A4/A7. OWASP ASVS L3.
- 72-hour breach playbook, rehearsed twice a year, with specific runbooks for outing, sextortion, intimate-media leak, insider abuse, account takeover and mass breach [B §9].

6.7 Authentication — account holder only (v1.2)

Implements 02 §3.3 (FR-056-FR-062, D-16).

- **WebAuthn relying party** in `identity-svc`. `userVerification=required`. Attestation is verified for native authenticators; the AAGUID allow-list is maintained.
 - B1 credentials must be platform authenticators flagged `bio_enrolment_bound`. The native apps send an App Attest / Play Integrity statement that the key was created with biometric-only access control and invalidation on enrolment change.
 - On the mobile PWA the browser cannot prove biometric-only verification. The server therefore requires B2 on **every** PWA login and on every step-up, while native B1 attestation lets step-ups inside an existing session use B1 alone, except for device add and recovery.
- **Login state machine** (Redis, 5 min TTL): `begin` → `factor1_ok` → (`liveness_pending` | `approval_pending`) → `session`. **No session token exists until both factors pass**. Partial states are bound to the DPoP key that started them.
- **Surface decision** is made on the server: native attestation → `mobile_app`; a registered platform authenticator on a mobile UA with no attestation → `mobile_pwa` (B1 + B2); anything else → `desktop` (F1 + F2). An unrecognised authenticator falls back to the strictest path available.
- **B2 provider adapter**: shares its interface with the two age-assurance providers (02 §3.1). Uses a randomised challenge and a 1:1 match against `login_reference`. Only `{match: bool, score, pad_pass: bool}` comes back to

TRYST; no image or template. **Fail closed:** a provider outage blocks new logins, not existing sessions. An in-session unlock never needs B2.

- **Cross-device approval (F2):** the QR code carries a single-use 60 s token bound to the desktop's DPoP key and coarse location. The approving app shows the desktop's browser, approximate city and time, and needs a fresh B1 assertion. No push notification is sent.
- **Risk controls:** rate limits per contact hint, device and IP; lockout escalation (5 failures → 15 min; 10 → recovery only). Every success and failure writes `auth_event`. A new-device login sends a masked in-app notice to the other registered devices. Impossible-travel and new-AAGUID signals force recovery-grade checks.
- **Recovery:** B2 + fresh V2 whose HMAC anchor_doc must equal the stored candidate (02 §4.1), then a 24 h hold. The hold is cancellable from any registered device and is never bypassable by staff (no break-glass path exists for authentication).
- **Lawful basis:** B2 is biometric processing for unique identification (Art. 9). It uses explicit consent `biometric_login`, recorded in the ledger. The accessible alternative (D-17) keeps the consent freely given (ToS Q14).
- **Cost:** about 1–2 B2 checks per mobile MAU per month (30 d sessions plus new devices and step-ups). At an assumed £0.10–0.30 per check this is £0.10–0.60 per MAU per month; it is added to the infra line in 01 §12. Replace with the vendor quote in P0.

7. Guardian — safety models (M6a–M6e)

7.1 Central problem

Source: A §21.1

Consensual power exchange looks identical to coercion at the token level. Guardian therefore classifies the **trajectory** of a conversation, not its content:

```
consent_state(t) = f(explicit_affirmations, explicit_refusals, limit_declarations,
                    enthusiasm_markers, reciprocity, initiative_balance)
RISK fires on:  refusal(t) ∧ escalation(t+k) · limit_stated(t) ∧ limit_approached(t+k)
               disengagement(t) ∧ persistence(t+k) · sustained asymmetric initiative
RISK never fires on: intensity, vocabulary, kink taxonomy, power-exchange framing, explicitness
```

Any model that separates consensual from coercive only through topic vocabulary is rejected at eval.

7.2 Models and thresholds

Source: A §19.3 L4, §21.2

ID	Target	Threshold action
M6a	Coercive control (isolation, monitoring, guilt leverage, secrecy framing imposed on the counterparty, identity erosion)	> 0.75 → queue; > 0.92 → thread freeze pending review
M6b	Boundary violation (escalation after a refusal, repeated declined request, approaching a hard limit, recasting a "no" as a "maybe")	> 0.70 → send-block + warning; 2nd → strike; 3rd → suspend
M6c	Off-platform pressure	> 0.65 → caution banner to the counterparty; feeds M5 and M6a
M6d	Identity/location pressure	Auto-redact in transit (client) + banner + strike on repeat
M6e	Image coercion and sextortion	Any hit > 0.60 → immediate freeze , human within 1 h. Tuned for recall

Serving:

- M6a–e run **on device** for E2EE threads, inline < 80 ms p95. Only a score + reason code + model version is sent to `/v1/guardian/signals`.
- Server-side: cross-account correlation on reason codes (the same script used against many people), M7/M7b, and profile/media moderation.
- Scores are calibrated (isotonic) so moderators can triage by probability. Thresholds are set per model, locale and segment, and reviewed monthly against the overturn rate.

7.3 Escalation matrix

Source: A §8.4

Signal	Automatic	Human SLA	External
Suspected minor	Immediate full freeze of both accounts; content preserved under legal hold	15 min	Mandatory report; law-enforcement liaison
Intimate image abuse / NCII	Media quarantine, hash to StopNCII, sender frozen	1 h	Takedown log; victim-support routing
Sextortion / coercion	Thread freeze, evidence preserved, victim safety banner	1 h	Action Fraud referral path
Threat of violence / stalking	Account suspended, mutual geo-suppression, device ban	1 h	Police referral on request
Romance fraud pattern	Payment-link stripping, shadow-limit, cohort sweep	4 h	Bank/PSP intelligence sharing
Commercial sexual services	Immediate removal	4 h	—
Harassment (M6 > 0.9)	Send-block, warning, strike	24 h	—

Evidence. Server-side evidence exists only when a member reports and **chooses** to disclose decrypted content, or when Panic preserves it. Reporter identity is stripped before evidence reaches labelling.

7.4 Training data

Source: A §21.3–21.4

Permitted sources only:

- D1: expert-authored synthetic corpus — 12k threads, **matched consensual/coercive pairs**, written with DV and kink-education specialists.
- D2: published taxonomies, used as the label schema.
- D3: public toxicity transfer, **not** as a source of coercion labels.
- D4: reported content with separate, revocable training consent (from P3).
- D5: active learning on the moderator queue (overturns are the most informative labels).

Never: scraped platform conversations without a lawful basis, purchased corpora of uncertain provenance, or survivors' disclosures collected for another purpose.

Annotation:

- Triple annotation on the coercion classes; Krippendorff's $\alpha > 0.70$ to accept a batch.
- Senior adjudication.
- Annotator welfare budgeted: rotation caps, clinical supervision, exposure limits on M6e material.

Bootstrapping:

Phase	Data	Expected performance
P1	Rules + D3	recall ~0.55 / precision ~0.30
P2	+ D1, D2	~0.82 / 0.61
P3	+ D4, D5	~0.91 / 0.74
P4	Per-language evaluation	

7.5 Profile and media moderation (server side)

Public-tier profile photos and bios are **not** E2EE and are moderated on the server:

- EXIF strip
- AI-generation detector and reverse-image search on **every** upload
- face consistency across the photo set
- C2PA provenance where present
- nudity classification (explicit content is web-only and V2-only)
- CSAM hash matching (IWF/NCMEC lists) before storage
- adversarial perturbation for A8

Private-tier media is client-encrypted; the sending client runs on-device checks before encrypting, including hash matching against licensed lists where licensing permits (D-10).

7.6 Evaluation gates and limits

Source: A §21.5–21.9

Ship gates:

Gate	Requirement
Matched-pair separation (hard gate)	AUC > 0.85
M6b	Recall > 0.90 at FPR < 0.03
M6e	Recall > 0.95, precision ≥ 0.35
Dialect FPR parity	Within 1.5× across groups
Counterfactual gender swap	Mean score delta < 0.05
Appeal overturn	< 8%
Moderator agreement	> 75%

Fairness slices: dialect/register (AAVE, MLE, regional), non-native English, gender, orientation/structure across S1–S6, age band. Audited quarterly.

Adversarial resistance:

- Quarterly red-team retainer.
- Rolling windows across messages and sessions.
- Cross-account correlation.
- Weekly drift checks. A sudden drop in positives means an evasion technique has been found, not that behaviour improved.

Guardian never:

- takes a permanent action without a named human;
- scores protected or inferred characteristics;
- produces a public or counterparty-visible score;
- reads message content on the server;
- flags on vocabulary alone.

8. Admission control (L1–L5)

Layer	Server responsibilities
L1 Identity binding	Liveness with a randomised challenge (provider); ID-document match through the provider; device attestation verification (App Attest / Play Integrity), emulator/root detection; payment-instrument fingerprint (token); £9.99 deposit. VPN/datacentre IPs are scored, never blocked
L2 Ban anchor	At V2, identity-svc stores anchor_candidate HMACs (E-02). On a permanent ban (human decision, reason_code), the candidates are copied to BAN-DB. On auth/verify (new identity), attestation and payment checks, and V2 completion, every anchor is checked; a match → silent refusal with a generic error that never names the anchor. Biometric anchor only if counsel confirms a lawful basis (D-08). A successful appeal destroys the anchors
L3 Attestation	Conduct declaration stored in the consent ledger; Basic DBS verified through the issuing route (no PDF uploads) and stored as {dated_fact}; Clare's Law content is static, with no field for the outcome
L4 Behavioural	Guardian M6a–e (on device), M7b ban-evasion graph → shadow-limit → human review → anchor extension
L5 Consortium	Interface built behind a feature flag: anchors + reason code only. Disabled until competition-law and data-protection opinions (ToS Q8)

Fake-profile stack [A §19.4]:

Stage	Checks
Sign-up	Liveness · ID match · GAN/deepfake detection on selfie and video · attestation · deposit
Media	C2PA · reverse-image · EXIF anomaly · face consistency · AI-generation classifier on every upload
Network	Score, never block
Graph	Sign-up bursts · shared device or payment · referral-chain anomalies
Behaviour	Typing cadence · templating · copy-paste · latency uniformity · slate-interaction entropy

Detectors are refreshed quarterly; a static detector is a known future failure.

Enforcement pipeline (FR-035): warn → shadow-limit → suspend → permanent + anchor → law-enforcement referral. Grounds g1, g3 and g4 go straight to permanent. `enforcement.decided_by` is required for permanent (DB constraint). Appeals are assigned to a different reviewer (enforced in the console) within 10 working days. Reporter-reputation scoring down-weights coordinated or retaliatory reports; one uncorroborated report never leads to a permanent ban [B §10].

9. MLOps and release gates

Model ship gates:

- Offline replay on held-out cohorts measuring **ΔR**, not AUC alone.
- Shadow → 5% → 25% → 100% rollout, with automatic rollback on report-rate or S4-churn regression.
- Model card + DPIA annex for each model.

Agent gates:

- 400-case golden set per agent: Envoy negotiation fidelity, Guardian adversarial recall, Cartographer extraction accuracy.
- Prompt-injection corpus.
- Run on every PR touching a prompt, policy file or agent code.

Audits:

- Quarterly fairness audit per protected characteristic and segment.
- Monthly counterfactual audit for popularity collapse (the 15% exploration floor is the structural defence).

Privacy Auditor [B §5]: continuous probes. It **blocks a release** if any of the following holds:

Probe	Blocks release if...	Mapped to
Media access	Media is reachable without an active grant	G-NG-1
Erasure	Erasure proof is missing or slow	G-NG-2
Location	Location can be triangulated (distance-band oracle tests)	G-NG-3
Tier	Any gated endpoint is reachable below V2	G-NG-4
Couple co-sign	A same-device co-sign is accepted	G-NG-5
Hard gates	Any hard-gate property test fails	G-NG-7
Client SDKs	A third-party SDK appears in a client SBOM	G-NG-8
Staff access	Any staff role can reach message plaintext	G-NG-9

10. Commerce

- **PSP:** dedicated high-risk acquirer (MCC 7273, Visa IRP Tier 1 registration) plus a **backup MID from day one**. Card data is tokenised and never touches TRYST.
- **Descriptor:** neutral and truthful, with a customer-service URL; enforced per MID.
- **Vouchers:** offline codes redeemed through `/v1/vouchers/redeem`, single-use, with rate limits and fraud scoring.
- **Subscriptions** (TRYST+, ENVOY, DUO, GHOST add-on): state machine with pre-contract information, cooling-off notice (CCR 2013), pre-renewal email (≥ 7 days), one-step cancel and end-of-contract notices. Built to the full DMCC regime now.
- **Keys ledger:** double-entry, idempotent. Intent spend is held and **refunded on reply**. Keys don't expire while the account is open. They are refunded on removal unless the ground is in ToS cl. 17.3, and are never forfeited before an appeal ends.
- **Chargebacks:** Ethoca/Verifi alerts → auto-refund rules. Alert at 0.5%; hard stop review at 0.65%.
- **Payment fingerprint** feeds L1 and the ExclusionRing heuristics (suppress only).
- **App-store purchases:** web-first. Where a store build must offer in-app purchase, entitlements are unified in `commerce.entitlement` (D-11).

11. Compliance engineering and operations

- **Consent ledger:** append-only, hash-chained (`entry_hash = H(prev_hash || record)`); verified nightly; exportable on SAR.
- **DSR service:** SAR export, rectification, erasure (§6.3) and portability, all built in sprint one [A §14.2].
- **OSA:** report SLAs are measured and published. Transparency data is produced from SAFETY-DB (FR-052). A named accountable manager owns the on-call escalation.

- **Article 22:** human review path for suspensions; decisions record `decided_by`.
- **Jurisdiction gate:** GeoIP at the edge + sign-up declaration + travel detection from coarse client location. The block list is versioned config, and each enabled market references its legal opinion ID.
- **Legal process:** published policy. Warrants or court orders are required. The member is notified where lawful. Only what exists is disclosed (ciphertext and minimal metadata).
- **Observability:** OpenTelemetry. Logs carry no content and truncate IPs at ingest (NFR-11). SIEM, plus anomaly alerts on staff access.
- **SLOs:** NFR-01, -02, -05, -13.

12. Backend backlog by phase

Phase	Epics (backend)	Definition of done
P0 (M0–M2)	Threat model; architecture review; assurance-provider adapters (×2) spike; PSP + backup MID integration spike; IaC landing zone (eu-west-2), KMS/HSM, isolated clusters; contracts repo (OpenAPI + Protobuf) generated from 02	Threat model signed off; G-P0 legal items done by others
P1 (M2–M6)	edge-gateway (DPoP, gates); identity-svc (sign-up OTP, devices, passkeys + two-factor login, step-up, recovery , assurance, anchors, join HMAC); core-svc modules: profile, couple (VC), intent (Keys, caps), discretion (policy, zones), reveal, threads (MLS DS), meet, consent, deletion, commerce (TRYST+, Keys, deposit, vouchers); Cartographer; Broker P1 (Stage 0 + weighted baseline); Curtain v1; Guardian server (signals intake, escalation, M7, media moderation); Aftercare; safety-svc + trust console; Privacy Auditor probes; DSR	FR-001-009, 011-014, 016-023, 026-044, 046-047, 049-051, 054, 056-062 met (backend side); NFR-01/02/05/06/10/11 met; no-go list clear; control cohort running (no Envoy)
P2 (M6–M10)	Envoy (agent + Briefs); Mirror v1 (M1–M4, α, reset/insights); ExclusionRing PSI; Guardian P2 models (D1/D2); FR-024/025	G-P2: meets per intent sent ≥ +40% vs control
P3 (M10–M15)	DUO, ENVOY, GHOST billing; ENVOY proposals; travel mode; DBS attestation; transparency report; 24/7 T&S tooling; scale to 25k verified	G-P3
P4 (M15–M24)	Multi-market jurisdiction config; localisation; per-language Guardian; consortium interface (if cleared); scale to 150k	G-P4

04 — TRYST Frontend Specification v1.1

Part of the TRYST v1.1 baseline. Consumes the contracts in 02. Product intent is in 01.

1. Scope

This document covers the native iOS and Android apps, the web PWA, the shared client crypto core, on-device models, UX flows, discretion and safety UI, copy rules, accessibility and store compliance. It does not redefine API shapes, enums or retention; those live in 02.

2. Two-surface strategy

Apple Guideline 1.1.4 and Google Play's age-restricted and anonymous-chat policies make two surfaces a **requirement** [A §14.3]:

	Native store builds (iOS, Android)	Web PWA
Role	Discreet companion: discovery, Briefs, threads, meets, safety, discretion	The full product and the primary revenue surface
Content	Sanitised. No nudity, no explicit imagery or copy in the app, listing or screenshots	Explicit media allowed behind V2 only , never shown during verification
Messaging	Matched only — never random or anonymous chat	Same
Billing	Web-first; in-app purchase only if a store requires it (D-11)	All billing, vouchers, deposit
Positioning	"Discreet dating"; 18+; Play Console minor-blocking on; Apple age questionnaire done	Full brand
Discretion strength	Strongest: decoy skin, duress PIN, Secure Enclave/StrongBox, FLAG_SECURE, backup exclusion	Reduced (browser limits): quick exit, neutral title/favicon option, session lock, private-browsing guidance

Explicit media sent from the web is delivered to native clients as a placeholder ("View on web"). It is never rendered in the store build (FR-051).

Store basics that cause most rejections: in-app account deletion, a web deletion link, privacy manifests, a working reviewer demo account (sanitised seeded data), and a Data Safety form that exactly matches the Privacy Notice.

3. Client stacks

Source: A §12

Surface	Stack	Notes
iOS	Swift / SwiftUI , iOS 17+	Keys in Secure Enclave; NSFileProtectionComplete; files excluded from backup; alternate app icons for the decoy
Android	Kotlin / Jetpack Compose , Android 10+	Keys in StrongBox where present (TEE fallback); FLAG_SECURE; allowBackup=false and data-extraction rules; activity-alias for the decoy
Web	Next.js PWA (installable), TypeScript	No third-party scripts; strict CSP; non-extractable WebCrypto keys in IndexedDB; service worker caches no personal data
Crypto core	Rust (OpenMLS, AES-GCM, OPRF client) compiled to Swift (UniFFI), Kotlin (JNI) and WASM	One audited implementation across all three surfaces
On-device ML	Core ML (iOS), TFLite/NNAPI (Android), ONNX Runtime Web (WASM/WebGPU)	Guardian M6a-e, nudity pre-send check, conversation-feature extraction
API client	Generated from contracts/openapi	DPOP proof per request, signed with the device key

React Native is not used. Source A rejects cross-platform shells because Secure Enclave/StrongBox, FLAG_SECURE, screenshot detection, decoy skin and backup exclusion are unreliable through them (E-07).

Client non-negotiables:

- **NFR-09** — no third-party analytics, advertising, attribution or crash SDKs that send data off-platform. Crash reporting is self-hosted with scrubbed payloads.
- **No social login. No contact upload** — contacts are only ever blinded on device for PSI.

4. Screens and flows (by loop)

4.0 Sign-in — account holder only (v1.2)

Implements 02 §3.3 (FR-056–FR-062).

Native app and mobile PWA — two biometric factors:

1. **B1:** a system biometric prompt (Face ID / Touch ID / BiometricPrompt BIOMETRIC_STRONG) unlocks the device-bound passkey. Device-passcode fallback is **disabled** for login.
2. **B2:** an in-app liveness capture with a randomised challenge (turn your head, read a short phrase) from the provider SDK (native) or web flow (PWA). The camera view uses brand colours with the night background. No logo is shown if a decoy skin is active.
3. The session is issued only after both succeed. Failure copy never says which factor failed.

Desktop browser / desktop PWA — two factors:

1. **F1:** the browser passkey prompt (Windows Hello / Touch ID / security key).
2. **F2:** a QR code appears on screen. The member opens TRYST on their phone, goes to **Approve sign-in**, scans it, and confirms with B1. The phone shows the desktop's browser, approximate city and time. Nothing is pushed to the phone's lock screen. Alternative: tap a second registered security key.

Other screens:

- **Biometric change detected:** "Your phone's fingerprints or face settings changed, so we've signed you out to protect your account." Then a full B1 re-registration + B2 login.
- **Unlock** (existing session): biometric or PIN per FR-027. The duress PIN opens the decoy.
- **Step-up sheet** for sensitive actions (02 §3.3). **Burn, Panic, report, block, cancel and delete never show a step-up.**
- **Recovery:** liveness → age/ID check with the same document → a 24 h countdown that any registered device can cancel → new passkey. The copy explains that support cannot bypass this.
- **Consent:** a separate biometric_login explicit-consent screen before V1, alongside the Article 9 consent, with a link to the accessible alternative (D-17).

4.1 Loop A — Quiet entry and intake

1. **Neutral landing / first launch.** On native, the member picks a decoy skin and neutral name at first launch.
2. **Contact (V0).** Email or phone OTP. Device key generated in the secure element; attestation sent.
3. **Discretion setup** (before any personal data): app PIN/biometric, duress PIN, notification mode (default **off**), Burn gesture, home/work zones (map picker → geohash-6 cells), and an honest **"What discretion can't cover"** card (P9).
4. **Liveness (V1)** through the provider SDK/web flow.
5. **Age assurance (V2)** with the ID match, then the **conduct declaration** (separate screen, logged) and the **Article 9 explicit consent** (separate from the ToS accept).
6. **Cartographer interview** (~7 min, conversational). Each proposed structured field is shown as an editable chip; the member confirms (FR-003). Desire tags offer three levels: yes / curious / no. Hard limits come from a controlled list with plain-language descriptions.
7. **ExclusionRing enrolment** (P2+). Opt-in. Explains that contacts are blinded on the device and that nobody learns who matched. Runs the OPRF client.
8. **Profile:** pseudonym, pronouns, free-text gender, age band (from assurance), photos. EXIF is stripped on device and face-blur is on by default; reveal ladder defaults come from the Discretion Policy.
9. **Safety notice** (FR-054) → first slate, or the waitlist if the city is gated.

Couples (VC). Partner A creates the couple and shows a QR or link (24 h). Partner B must complete V2 **on their own device**. Both review and approve the exact profile version. Veto mode is chosen jointly. The UI explains that either partner can dissolve the couple at any time without giving a reason.

4.2 Loop B — Discovery

- **Slate view:** up to 18 cards; no infinite scroll, no swipe mechanic.
- **Each card shows:** pseudonym, age band, distance band, modes, verification tier, and 2–4 reason chips with a "not quite" correction control (FR-025). Paid placement is labelled visibly.

- **Actions:** Send Intent (shows the Keys cost and the "refunded if they reply" promise), Pass, Save.
- Intent sending is **never** blocked by the counterparty's inbound cap, and the UI never reveals it.
- **My Signals** (P2): categories the system has learned, with correct, reset and personalisation on/off (FR-024).

4.3 Loop C — Handshake

- **Brief screen:** a persistent "**Prepared by Envoy (automated)**" label; aligned items; friction items with suggested resolutions; blocking items; estimated meet probability shown as a band (low / medium / high), never a precise number to the member.
- **Decisions:** Accept / Decline / Amend (amend chooses alternative values from the schema; no free text).
- **Couples:** the decision UI reflects the veto mode (e.g., "Waiting for your partner").
- **ENVOY tier** (P3): a proposal inbox where every proposed intent needs **one-tap approval**. Nothing is sent automatically (D-04).

4.4 Loop D — Thread and resolution

- **Thread (MLS):** text, view-once/timed media, voice/video calls (reveal-ladder gated). Retention selector (7/30/90 days; the shortest wins). Burn-thread action.
- **Reveal ladder control:** grant or revoke per recipient and scope. A revoked item immediately shows as unavailable on the recipient's device.
- **Meet planner:** propose/confirm. Safe Meet checklist (public venue first). Check-in timer. **Share My Plan** (FR-021). Clare's Law explainer before the first meet (P3).
- **Aftercare** (48 h): a two-tap private prompt (happened? as represented? would repeat? + optional safety flag).

4.5 Account

Pause, Vanish, Delete (shows the erasure promise **and** the declared exceptions in plain words), Export, Devices, Consents, Subscription (one-step cancel), Vouchers, Appeals.

5. Client discretion controls

Control	Native	Web	Req
Decoy skin — generic utility (calculator / notes) with a neutral icon and name; the real app needs a distinct PIN or biometric	✓	Neutral title/favicon option only	FR-027
Duress PIN — opens a populated, innocuous decoy state; silent	✓	—	FR-027
Quick exit — one action hides content and clears the view in < 500 ms (web: replace history and navigate to a neutral page)	✓	✓	FR-029
Burn — long-press, confirm in < 2 s: wipe local storage, revoke device keys (POST /v1/burn), sign out everywhere. Visually and gesturally distinct from Panic	✓	✓	FR-028, E-21
Notification masking — off by default; if on, the payload is content-free ("1 update") and the push contains no name, preview or image	✓	✓ (web push)	FR-026
Screenshot protection — Android FLAG_SECURE; iOS capture detection that blurs content and notifies the counterparty; obscured app-switcher snapshot	✓	Best-effort blur on visibility change	FR-030
No cloud backup — excluded from iCloud/Google backup; keys non-exportable	✓	Keys non-extractable	FR-030
Zone awareness — coarse client location checked against zones on device; "You're inside your work zone — hiding profile for 2 h"	✓	Optional	FR-011
Jurisdiction auto-lock — entering a blocked country switches to the decoy and hides the profile	✓	Edge-enforced	FR-031
Watermarking — recipient-specific visible/invisible watermark on revealed media; no-download viewer	✓	✓	A §9.1 A5

Location never leaves the device at better than geohash-5, except in the Panic flow.

6. Client cryptography and on-device intelligence

- **Device identity:** a key pair generated in the secure element, used for DPoP proofs and as the MLS credential. Rotated on re-install; revoked by Burn.
- **Messaging:** OpenMLS. One MLS group per thread (2, 3 or 4 members). Key packages are uploaded to the delivery service.
- **Media:** a per-media AES-256-GCM key; ciphertext uploaded through a pre-signed URL; the key is wrapped per recipient (MLS exporter secret) and sent in band. **Revocation** asks the server to destroy the wrapped key, and the recipient client purges any cached plaintext.

- **PSI client:** normalise contacts (E.164 / lowercased email) → hash → blind with a random r → server evaluates → unblind → upload the PRF set. Raw contacts never leave the device; nothing is shown to the member about matches.
- **Guardian on device (FR-033):** M6a–e run on each thread turn over a rolling window (< 80 ms p95). Only {model_id, version, score, reason_code} is posted. Local UI responses:
 - M6d auto-redacts addresses and phone numbers in outgoing text and asks the sender to confirm;
 - M6c shows a caution banner to the counterparty;
 - M6e locks the thread pending review.
- **Pre-send media check:** on-device nudity classifier (explicit media only to V2 web, with the counterparty's media-view consent), plus licensed hash matching where permitted (D-10).
- **Conversation features** for M5 and Mirror (length bucket, latency, question ratio) are computed on device. **No content leaves the device.**
- **Reporting:** the reporter may choose to attach decrypted messages or media. This is an explicit, separately confirmed disclosure, with a separate opt-in for safety-model training (never a condition of action).

7. Safety UX

Safety notice (FR-054; shown at intake and before a first meet) [A §20.3]:

Before you meet anyone. We verify that members are real adults. We do not — and cannot — check anyone's criminal record, their honesty, or whether they are who they say they are once you are off this app. No UK platform can. Meet in public the first time. Tell someone where you are going; Share My Plan does it privately. Trust your instincts and leave if something feels wrong. If anyone pressures you, threatens you, or pushes past a boundary you set, report them — we act on it, and we do it fast.

- **Panic** (FR-022): a prominent, distinct control in threads and the meet screen. It confirms with a hold, sends live location + preserved evidence through POST /v1/safety/panic, and offers a one-tap call to 999. It works even when notifications are masked or the app is in decoy mode (reachable through a gesture from the decoy).
- **Share My Plan:** pick a trusted contact (stored locally only). It sends a neutral, unbranded, auto-deleting message with venue and time window through the device's share sheet or an encrypted link. The wording is chosen for someone who cannot tell their partner where they are.
- **Check-in timer:** a missed check-in triggers silent escalation to the trusted contact.
- **Report / block:** one tap on every profile, Brief, thread and media item. The reporter is never revealed.

7.1 Copy rules (claims discipline, P6)

Source: A §19.8

Never	Use
"Background checked", "Safe", "Vetted", green "safe" ticks	"Identity verified", "Age assured", dated facts ("Submitted a Basic DBS dated 14 Mar 2026")
"No sex offenders"	"We permanently remove and block re-registration where we find harmful conduct"
"Guaranteed real"	"Every member completes liveness and ID verification"
"Undetectable", "No trace"	"We minimise what we store, and here's what we can't control"
"Cheat better" or any affair-shaming or affair-glamorising copy in the store build	"Discreet dating"; "Discretion is the product" (web)

7.2 Brand application (v1.2)

Logo. Use assets/brand/tryst-logo.png **exactly as supplied:** no redraws, recolours, crops or effects. Place it on night, oxblood-deep or oxblood only. Never show it in decoy mode, on lock screens, in notifications, app-switcher snapshots or Share My Plan (FR-063; 01 §3.1). For small sizes (favicon, ≤ 48 px) use the PNG scaled down. If it is illegible at that size, the web favicon defaults to the neutral option (FR-027) rather than a modified logo.

Colour. Import assets/brand/tokens.css (web) or generate native colour assets from tokens.json. Defaults:

Element	Token
Background	night
Cards	oxblood-deep

Element	Token
Body text	cream
Headings and accents	gold
Primary button	oxblood with champagne text
Borders	oxblood-light
Disabled	bronze

Type: serif display with tight tracking for headings, matching the wordmark; a clean sans for body text. **Never** pink, hearts or silhouettes [A §2]. The decoy skins use their own neutral system palettes, never brand tokens.

8. Accessibility, localisation, performance

- Accessibility:** WCAG 2.2 AA on web (brand text pairs pass AA, 01 §3.2); VoiceOver/TalkBack labels on native; Dynamic Type; reduced motion. The decoy and quick-exit controls must be operable by assistive technologies **without announcing "TRYST"** (NFR-07). Members who cannot use face or fingerprint biometrics get the accessible sign-in alternative (D-17).
- Localisation:** EN-GB/EN-IE at P1; NL, DE, SV, DA, ES, PT at P4 (NFR-14). Brief and Guardian copy is code-based for localisation.
- Performance:** cold start < 2 s on mid-tier devices; slate first paint < 1 s after the API response; quick exit < 500 ms; Burn confirmable < 2 s (NFR-04).
- Platforms:** iOS 17+, Android 10+, evergreen browsers (NFR-15).

9. Client testing and release

- Contract tests against generated mocks of 02. A UI tier-gate test checks that no screen shows other members' content below V2.
- Security: MASVS L2 + R checks, jailbreak/root behaviour, screenshot and backup tests, SBOM scan with zero third-party telemetry SDKs (G-NG-8).
- On-device model benchmarks per device class (NFR-03).
- Store review pack:** sanitised build flag, reviewer demo account, privacy manifest, Data Safety form diffed against the Privacy Notice in CI.

10. Frontend backlog by phase

Phase	Epics (frontend)	Definition of done
P0 (M0–M2)	Design system (oxblood/bone); discretion UX prototypes (decoy, duress, quick exit, Burn vs Panic) usability-tested; Rust crypto core spike on three targets; store pre-review consultation	Prototypes validated; crypto core builds on iOS, Android and WASM
P1 (M2–M6)	Web PWA (full product) + native apps (TestFlight / internal track): onboarding V0–V2, conduct and Article 9 consent, Cartographer UI, profile/media with client encryption, couple co-sign, slate, intents/Keys, threads (MLS), reveal ladder, meet/Safe Meet/Share My Plan/Panic, Aftercare, discretion suite, on-device Guardian baseline, report/block, account/DSR, web billing (TRYST+, Keys, deposit, vouchers)	FR-001–009, 011–013, 016–023, 026–033, 037–039, 041–042, 044, 046–047, 049, 051, 054, 056–063 met (client side); NFR-03/04/07/09/15 met
P2 (M6–M10)	Brief screens + decisions; My Signals; ExclusionRing enrolment (PSI client); reason chips	FR-010, 015, 024, 025
P3 (M10–M15)	DUO, ENVOY (proposal inbox), GHOST UI; travel mode; DBS attestation and Clare's Law explainer; store submissions approved on both platforms	G-P3 store approval; FR-045, 048, 053
P4 (M15–M24)	Localisation (6 languages); market-specific copy and assurance flows	NFR-14

05 — TRYST Terms of Service — Draft 0.9.2

Part of the TRYST v1.1 baseline.

Draft for counsel review. Not legally reviewed. Do not publish or rely on in this form. Prepared by: Product. For review by: UK consumer, Online Safety Act and data-protection counsel. Governing law assumed: England & Wales.

Changes from draft 0.9 (Source A, Part B) are marked **[v1.1]**. They align the terms with specification v1.1 (06 §3: E-02, E-09, E-10, E-11) and add counsel questions Q11-Q13. Clause numbers are unchanged; one clause (3.5) is added.

Note to counsel. This draft is written by the product team to be reviewed, not approved. Clauses carrying the highest legal risk are marked **REVIEW** with a specific question. Three areas need particular attention:

- **clause 15** — retention of exclusion identifiers after account deletion: the lawful-basis question;
- **clause 16** — the subscription regime, whose commencement date is unsettled;
- **clauses 21-23** — the liability structure, drafted deliberately narrow so that it survives s.62 rather than broad so that it gets struck.

1. These terms, and who we are

1.1 TRYST is operated by [SPV NAME] LIMITED, a company registered in England and Wales (No. [—]), registered office [—]. In these terms, "we", "us" and "our" mean that company. "You" means the person using TRYST.

1.2 These terms are a contract between you and us. They apply whenever you use the TRYST website, apps or any related service.

1.3 They are written to be readable. Where a clause matters to you, we have added a plain-English box explaining it. Those boxes are part of these terms and can be relied on.

1.4 Our Privacy Notice, Community Rules and Safety Policy form part of these terms.

2. Definitions

2.1 **Member** — a person with a TRYST account. **Couple Profile** — a profile representing two Members who have each independently confirmed the link. **Keys** — the prepaid credits described in clause 16. **Intent** — an outbound expression of interest. **Brief** — the agent-generated summary described in clause 7. **Exclusion Identifier** — the irreversible identifier described in clause 15.

3. Who can use TRYST

3.1 You must be 18 or over. We verify this using age-assurance methods that meet the "highly effective" standard under the Online Safety Act 2023. If we cannot verify that you are an adult, you cannot use TRYST, and there is no appeal against that.

3.2 You must have the legal capacity to enter this contract, and you must not be prohibited from using a service of this kind by any court order, licence condition or notification requirement.

3.3 TRYST is available only in the countries listed at [URL]. We block access elsewhere, including in countries where using a service of this kind could expose you to criminal liability. You must not attempt to circumvent that block.

3.4 You may hold one account. If you previously held an account that we permanently closed under clause 17, you may not open another.

3.5 **[v1.1]** When you verify your age, we ask you to declare that you have no unspent convictions for sexual or violent offences, and that you are not subject to a Sexual Harm Prevention Order, a restraining order or a non-molestation order. We record that declaration separately. A declaration you knew to be false is grounds for permanent removal under clause 17.3.

4. What TRYST is

4.1 TRYST is an introduction and discovery platform. We provide software that lets adults find one another, communicate, and decide for themselves whether to meet.

4.2 We are not a matchmaking agency, an introduction agency acting on your behalf, an escort or companionship service, or a party to anything you arrange with another Member. We do not act as your agent and we owe you no duty to find you anyone.

4.3 We do not select, endorse, recommend, approve or vouch for any Member. Our software ranks and suggests profiles; that is a computational output, not a recommendation from us that a person is suitable, honest or safe.

IN PLAIN ENGLISH — We introduce people. What happens after that is between you and them. Nothing we show you is us telling you that someone is a good idea.

5. What we verify — and what we do not

5.1 We do verify, before a Member can send an Intent or exchange media: that they are an adult; that they are a real, living person, by liveness check; that their photographs are of them; and, for a Couple Profile, that both partners have independently confirmed the link from their own separate devices.

5.2 We do not verify, and cannot verify:

- your relationship or marital status;
- whether a partner of yours knows about, or consents to, your use of TRYST;
- your criminal record, or whether you are subject to any order or notification requirement;
- your employment, income, health or personal circumstances;
- the truth of anything you or any other Member says.

5.3 There is no lawful route by which a UK platform can check a Member against the sex offenders register or obtain a criminal-record check on them. We do not claim to do so, and you should treat any platform that claims otherwise with caution.

5.4 Membership of TRYST is not, and must never be read as, a statement by us that a Member is safe, honest, available, unattached, or suitable for you.

IN PLAIN ENGLISH — We check you are a real adult who looks like your photos. We do not check your marriage, your record, or your honesty. No UK app can check a criminal record on you — and we will never pretend we have.

REVIEW — Clause 5 is drafted to anchor the whole liability structure and to keep us clear of the CPUT Regulations and the DMCC Act consumer regime on misleading practices. Please confirm the wording is strong enough to defeat an argument that our verification badges, ranking or marketing create an implied representation of safety.

6. Your account

6.1 Everything you tell us about yourself must be accurate, and your photographs must be current and of you. Profiles that misrepresent who you are will be removed.

6.2 Keep your access credentials, PIN and device secure. Tell us immediately if you think someone else has access to your account.

6.5 **[v1.2]** Only you may sign in to your account. Signing in needs two checks. On a phone (app or website), these are your phone's fingerprint or face unlock **and** a live face check matched to you. On a computer, they are a passkey **and** approval from your registered phone. We never let anyone sign in by text message or email code, and our staff cannot sign in for you or bypass these checks. If you cannot use face or fingerprint checks, we offer an alternative (see our Accessibility page at [URL]).

IN PLAIN ENGLISH — Even someone holding your unlocked phone cannot get into your account. If anyone adds their fingerprint or face to your phone, we sign you out.

6.3 You are responsible for everything done through your account, unless someone gained access through our failure to take reasonable care.

6.4 You may not sell, transfer, rent or share your account.

7. Couple Profiles, and our agent features

7.1 A Couple Profile requires both partners to hold their own verified accounts and each to confirm the link from their own device. We will not create a Couple Profile on one person's say-so. Either partner may dissolve the link at any time, and we will act on that immediately without telling the other partner why.

7.2 Some features use automated agents. Before you and another Member speak, our agents may exchange structured information about intentions, boundaries, availability and verification, and produce a Brief for each of you.

7.3 Our agents never pose as you, and never speak to another Member as if they were you. Every Brief is labelled as automatically generated. A Brief is information to help you decide; it is not advice, and it is not a judgement about whether someone is safe. **[v1.1]** Where you use a paid agent feature that suggests people to contact, nothing is sent until you approve it.

7.4 A conversation only opens when both of you have seen your Brief and accepted.

IN PLAIN ENGLISH — Our software does the awkward pre-screening so you don't waste weeks. It never pretends to be you, and it never tells you someone is safe.

8. Community Rules — what you must not do

You must not, on TRYST or in any contact that begins on TRYST:

- be under 18, or attempt to contact anyone you believe or suspect is under 18;
- share, request, or threaten to share intimate images of anyone without their consent;
- pressure anyone for images, contact, money, or sexual activity, or continue after someone has said no;
- threaten, harass, stalk, intimidate, or attempt to coerce or control another person;
- misrepresent your identity, age, or appearance, or use another person's images;
- offer or seek sexual services in exchange for money or anything of value;
- attempt to identify, locate, contact, or expose a Member outside TRYST without their agreement, or disclose that someone is a Member to anyone;
- solicit money, investment, or financial information;
- record, screenshot or copy another Member's private content or messages;
- use TRYST for any commercial, promotional or research purpose;
- scrape, reverse-engineer, or automate access to TRYST;
- evade a suspension or removal.

8.1 Exposing a Member's use of TRYST to a third party is one of the most serious things you can do on this platform, and we treat it as grounds for immediate permanent removal.

9. Your conduct and your decisions

9.1 You decide who to speak to, what to tell them, whether to meet, where, when, and what happens when you do. Those are your decisions.

9.2 You are responsible for your own conduct. Another Member is responsible for theirs. We are not responsible for what any Member says, does, or fails to do — subject always to clause 22.

9.3 You accept that other Members may misrepresent themselves despite our checks, and you agree to take reasonable care of your own safety, including using the safety features in clause 11.

10. Consequences outside TRYST

10.1 We are not responsible for the effect of your use of TRYST on your relationships, marriage, family, employment, finances or reputation. Those consequences are yours.

10.2 No person who is not a party to this contract acquires any right under it. The Contracts (Rights of Third Parties) Act 1999 does not apply.

REVIEW — Clause 10.2 is intended to head off a claim by a Member's spouse or partner. Please advise whether it is sufficient, and whether any free-standing duty could arise in tort notwithstanding it.

11. Safety features — and their limits

11.1 We provide safety features including Safe Meet guidance, Share My Plan (which privately tells a contact of your choosing where you are going), a check-in timer, in-app reporting, blocking, and a Panic control that contacts emergency services.

11.2 These features are aids. They depend on your device, your network, and third parties we do not control. We cannot guarantee that any of them will work at the moment you need it, and you must not rely on any of them as your only safeguard. If you are in danger, call 999.

11.3 Using a safety feature does not make a meeting safe, and choosing not to use one does not make what happens to you your fault.

REVIEW — Clause 11.2 is a statement about technical limits, not an exclusion of liability for negligent design or operation of the features themselves — which we accept we cannot exclude under CRA 2015 s.65 where personal injury results. Please confirm the drafting does not stray across that line, since a term that did would be void and would jeopardise clause 21.

12. Your content

12.1 You keep ownership of everything you upload. You give us a limited, non-exclusive licence to host, store, encrypt, transmit and display your content solely to operate TRYST for you. That licence ends when your content is deleted, save as set out in clause 15.

12.2 Your private messages are end-to-end encrypted. We relay them; we cannot read them. This means we cannot recover them for you, and it also means we cannot moderate their content directly — we rely on your reports and on signals available to us outside the message content.

12.3 Media you send is encrypted on your device. You can revoke access at any time, which makes it permanently unreadable to the recipient. We cannot stop someone photographing their own screen with another device, and you should assume anything you send may be kept.

IN PLAIN ENGLISH — We genuinely cannot read your messages. That protects you, and it also means we can only act on what you report. Assume any photo you send could be kept, whatever our software does.

13. Intimate images

13.1 Sharing or threatening to share an intimate image of someone without their consent is a criminal offence. On TRYST it results in immediate permanent removal, preservation of evidence, and referral to the police.

13.2 If an intimate image of you has been shared without your consent, report it to us. We will act within the time stated in our Safety Policy, support you in submitting a hash to StopNCII where you wish, and preserve evidence for any investigation.

14. Your personal data

14.1 Information about your sex life and sexual orientation is special category data under the UK GDPR. We process it only on your explicit consent, which you give separately from accepting these terms, and which you can withdraw at any time.

14.2 Our Privacy Notice explains what we collect, why, how long we keep it, and your rights. It is not a summary — it is the operative document, and it prevails over anything in these terms about personal data.

14.3 We do not sell your data, we do not show advertising, and we do not embed third-party tracking in our apps.

15. Keeping and deleting your information

15.1 You can delete your account at any time. When you do, we destroy the encryption key that protects your data, which makes it permanently unreadable. This happens in under a minute and cannot be reversed. We cannot restore a deleted account.

15.2 Messages are deleted after 30 days by default, or after 7 or 90 days if you choose. Media **[v1.1] that you send in a conversation** is deleted after 7 days by default. **[v1.1] Your profile photos stay until you remove them or delete your account.**

15.3 There is one exception, and we want you to read it. If we permanently remove you because your conduct endangered another person, we keep a small set of Exclusion Identifiers — irreversible one-way codes derived from your identity document, device and payment method. We cannot reverse them into your personal details. We keep them so that you cannot open another account, and we keep them after your account is deleted. We do this to protect other people. We keep no evidence, no messages and no profile alongside them — only the codes, a category of reason, and the date. **[v1.1]** To make this possible, we create these codes when you verify and keep them protected with the rest of your account. If you delete your account and have not been removed under clause 17.3, they are destroyed with everything else.

15.4 If you are removed on that basis you may appeal under clause 18, and if your appeal succeeds we destroy the Exclusion Identifiers.

IN PLAIN ENGLISH — Delete your account and it is genuinely gone. The one thing that survives is a code that stops a removed predator coming straight back under a new name. If that is you and we got it wrong, appeal and we delete it.

REVIEW — This is the highest-risk clause in the document. We need: (a) the specific DPA 2018 Sch. 1 condition relied on — we have assumed Pt. 2 para. 18 (safeguarding of individuals at risk) — confirmed in writing; (b) a view on whether retention after erasure is defensible against an Art. 17 request; (c) confirmation that the disclosure is prominent enough, given that the rest of clause 15 promises complete erasure. We have deliberately refused to bury this. Please tell us if it needs to be more prominent still. **[v1.1]** See also Q13 on creating the codes for every verified member.

16. Paying for TRYST

16.1 Basic membership is free. Replying to any Member is always free. Paid tiers and Keys are described at [URL], with prices shown before you pay.

16.2 **Billing discretion.** Your card or bank statement will show a neutral descriptor that does not name TRYST. You can also pay using prepaid vouchers bought elsewhere. We do this because your privacy matters, not to obscure what you are paying for — the descriptor includes a customer service address.

16.3 **Cancelling.** You can cancel a subscription at any time, from inside the app or website, in one step. We will not ask you to call us, email us, or answer questions to cancel. Cancellation takes effect at the end of your current paid period.

16.4 **Your 14-day right to cancel.** Under the Consumer Contracts Regulations 2013 you normally have 14 days to cancel a distance contract. If you ask us to start the service immediately, you may lose that right for digital content, or owe us a proportionate amount for services already supplied. We tell you this clearly at checkout and ask you to confirm it separately.

16.5 **Reminders.** We email you before any renewal and before any trial converts to a paid subscription. The reminder says what you will be charged, when, and how to stop it.

16.6 **Keys.** Keys spent on an Intent are refunded in full if the Member replies. Unused Keys do not expire while your account is open. If we permanently remove you, unused Keys are refunded unless removal was on a ground in clause 17.3.

16.7 **Refunds.** Where we owe you a refund we pay it to the original payment method within 14 days.

REVIEW — The DMCC Act 2024 subscription regime is not yet in force, and its commencement date has moved repeatedly. We have drafted to comply with the full regime now, on the view that pre-contract information, reminder notices, cooling-off notices, end-of-contract notices and one-step cancellation are things we want anyway, and that retrofitting a payments flow is expensive. Please confirm the current commencement position

and whether clause 16 already meets it, particularly on the form and prominence of the notices. Note CMA fining powers of up to 10% of global turnover.

17. Suspension and removal

17.1 We may warn you, limit your account, suspend it, or remove you permanently if you break clause 8, these terms, or the law, or if we reasonably believe you present a risk to another person.

17.2 We will tell you what ground we acted on, unless telling you would put someone at risk or prejudice an investigation. A permanent removal is always decided by a named person at TRYST, never by software alone.

17.3 Immediate permanent removal, with Exclusion Identifiers retained under clause 15.3, applies where:

- you are under 18, or sought contact with someone you believed to be under 18;
- you shared or threatened to share intimate images without consent;
- you coerced, threatened or attempted to control another person;
- you exposed a Member's use of TRYST;
- you are subject to a relevant court order; or
- you knowingly gave a false declaration under clause **[v1.1] 3.5**.

17.4 We may preserve evidence relating to a removal beyond the periods in clause 15, where we need it for an investigation, an appeal, or a legal claim.

17.5 Reporting another Member falsely, or organising others to report someone, is itself grounds for removal.

18. Appeals

18.1 You can appeal any suspension or removal by [route]. A different person from the one who made the decision will review it, and we will respond within 10 working days.

18.2 If we were wrong, we restore your account, refund anything you lost, and destroy any Exclusion Identifiers.

18.3 We publish, twice a year, how many accounts we removed, on what grounds, how many appealed, and how many appeals succeeded.

19. Reporting, and what we do about it

19.1 Report anything from inside any conversation or profile. Reporting takes one tap and you never have to explain yourself to the person you are reporting.

19.2 Our response times for each category of report are published in our Safety Policy. We do not hide them.

19.3 We will never tell the person you reported that it was you.

20. Emergencies come before privacy

20.1 Our privacy and deletion commitments are strong. But if there is a risk to someone's life or of serious harm, or where the law requires it, we will preserve and disclose whatever is necessary to the emergency services, the police, or a court.

20.2 We publish what we disclose, in aggregate, in our transparency report.

IN PLAIN ENGLISH — If someone's life is at risk, safety wins over discretion. Every time.

21. Our liability to you

21.1 We will supply TRYST with reasonable care and skill, as the Consumer Rights Act 2015 requires. Nothing in these terms limits that obligation.

21.2 We are not liable to you for the acts or omissions of another Member, or for anything that happens between you and another person, except where our own failure to take reasonable care caused it.

21.3 Where we are liable to you for financial loss, our total liability is limited to the greater of (a) the amount you paid us in the 12 months before the event, or (b) £100.

21.4 We are not liable for loss of profit, loss of opportunity, loss of reputation, or any indirect or consequential loss.

21.5 We are not liable for failures caused by events outside our reasonable control, or by your device, network or operating system.

22. What we do not exclude

22.1 Nothing in these terms limits or excludes our liability for:

- death or personal injury caused by our negligence, including any impairment of mental health;
- fraud or fraudulent misrepresentation;
- any breach of the obligations the Consumer Rights Act 2015 says we cannot exclude;
- our duties under the Online Safety Act 2023 and data protection law;
- anything else that cannot lawfully be limited or excluded.

22.2 Your statutory rights as a consumer are not affected by these terms. Agreeing to these terms does not mean you have accepted any risk.

REVIEW — Clause 22 is deliberately included and deliberately broad. We understand it removes any argument that we tried to exclude what CRA 2015 s.65 bars, and that s.65(2) means a "use at your own risk" framing would buy us nothing anyway. Our working assumption is that a narrow, honestly carved limitation survives the s.62 fairness test where an all-encompassing one would be struck out in full, taking clause 21 with it. Please confirm — and please push back if you think clause 21.3's cap is too low to be reasonable given what Members pay.

23. Your liability to us

23.1 If you break these terms or the law and that causes us financial loss — including a claim by another Member, a fine, or the cost of responding to an investigation — you agree to cover that loss.

23.2 This covers financial loss only. It does not apply where the loss was caused by our own failure to take reasonable care, and it is limited to what is reasonably foreseeable.

24. Changing these terms

24.1 We may change these terms. If a change materially affects you, we will tell you at least 30 days before it takes effect and explain what has changed and why.

24.2 If you do not accept a material change, you can close your account before it takes effect, and we will refund any unused prepaid amount in full.

24.3 We will not change these terms retrospectively.

25. Ending this agreement

25.1 You can close your account at any time, from inside the app, in one step.

25.2 Clauses 9, 10, 12, 13, 15, 17.4, 21, 22 and 23 survive the end of this agreement.

26. Complaints

26.1 Complain to [email]. We acknowledge within 2 working days and respond substantively within 10.

26.2 If you are not satisfied, you may refer the matter to [ADR provider], or contact Citizens Advice. Nothing here stops you going to court.

26.3 Our Online Safety Act complaints route, and the name of the senior manager accountable for it, are at [URL].

27. Law and courts

27.1 These terms are governed by the law of England and Wales.

27.2 You can bring proceedings in the courts of England and Wales. If you live in Scotland or Northern Ireland, you can also bring proceedings there. If you live elsewhere in a country where consumer law gives you the right to sue locally, that right is not affected.

27.3 There is no arbitration clause and no class-action waiver in these terms.

REVIEW — We have deliberately not included mandatory arbitration or a class-action waiver. Our view is that both are vulnerable under CRA 2015 s.62 and Sch. 2 in a consumer contract, and that including them invites CMA attention for limited benefit. Please confirm or overrule.

28. Contacting us

28.1 General: [email]. Safety and urgent reports: [route], monitored 24 hours.

28.2 Data protection: our Data Protection Officer at [email]. You can also complain to the Information Commissioner's Office.

28.3 Online Safety Act accountable senior manager: [name/role], [email].

29. Open questions for counsel

#	Question	Clause
Q1	Confirm the DPA 2018 Sch. 1 condition for retaining Exclusion Identifiers after erasure, and its resilience against an Art. 17 request.	15.3
Q2	Does any part of clause 11 stray into excluding liability for negligent design of a safety feature, which would be void under s.65 and could taint clause 21?	11.2
Q3	Is the £100 / 12-month cap reasonable, or does the low free-tier ARPU make it vulnerable under s.62?	21.3
Q4	Current commencement position for the DMCC subscription regime, and whether clause 16 meets it in full.	16
Q5	Could a Member's spouse establish a free-standing duty of care in tort notwithstanding clause 10.2?	10.2
Q6	Do our verification badges, ranking outputs or marketing create an implied representation of safety that clause 5 fails to displace?	5
Q7	Does clause 12.2 (we cannot read E2EE messages) weaken our OSA position, and how should the risk assessment address content moderation without content access? (See spec D-10.)	12.2
Q8	Is a cross-platform exclusion consortium (spec [v1.1] Source A §19.3 L5 ; v1.1 03 §8) viable under competition law and joint controllership?	—
Q9	Confirm the geo-block list, and whether operating in any listed market creates exposure for directors.	3.3
Q10	Review the Community Rules and Safety Policy as incorporated documents for consistency with these terms.	1.4
Q11 [v1.1]	Is scarce-side seeding that offers free paid features to women-identifying members lawful under the Equality Act 2010 (services), or must it be segment-based? (Spec D-06.)	16
Q12 [v1.1]	Does gating all discovery, Intents, conversations and media at age assurance (V2), with no other members' content visible before then, satisfy Ofcom's highly-effective-age-assurance expectations for dating services, including the May 2026 dating guidance?	3.1, 5.1
Q14 [v1.2]	Biometric login (clause 6.5) processes biometric data to identify the account holder. Is explicit consent valid (freely given) when login requires it, given the accessible alternative? Is a provider-held face reference compatible with clause 15's erasure promise if the provider's deletion completes after our 60-second erasure?	6.5, 15
Q15 [v1.2]	Does requiring biometrics to sign in, with the alternative path, meet the Equality Act 2010 reasonable-adjustment duty for disabled members?	6.5
Q13 [v1.1]	Is creating Exclusion Identifier codes for every verified member at verification (destroyed on deletion unless the member is removed) proportionate, and does it need its own Art. 9/10 and Sch. 1 analysis separate from post-removal retention? Should a biometric code ever be used (spec D-08)?	15.3

06 — Decisions, errata and change log (v1.1)

Part of the TRYST v1.1 baseline.

1. How v1.1 was reconciled

- **Precedence:** Source A (consolidated Spec + ToS, 4 Oct 2026) > Source B (Developer Specification, 17 Sep 2026) > Source C (PRD draft v0.1). See 00 §2.
- **Where A is silent,** B's requirements are kept: the Discretion Policy object, reveal ladder, preference transparency, quick-exit timing, Privacy Auditor, no-go conditions, the weighted P1 ranker and mode names.
- **From C:** non-functional requirements, the couple dissolution and data-export APIs, and the competitor rows. C's US expansion, its pricing and its unit economics are dropped.
- **Where A contradicts itself or contains an arithmetic error,** v1.1 fixes it and records it in §3.

2. Decision log

Status: *Resolved* = decided by a source document. *Default* = decided in v1.1 to remove ambiguity, and reversible by the owner. *Open* = needs an owner decision by the gate shown; build against the stated default until then.

ID	Decision	Status	Resolution / default	Owner · deadline
D-01	Are unattached singles allowed?	Open (v1.2)	The founder scope statement (01 §1) says TRYST is designed for adults already in a relationship, while Source A §3 includes solos open to couples (S4) and the curious (S6), who may be unattached. Default: the product and marketing target partnered adults and couples; unattached solos are <i>accepted</i> as S4 (needed for THIRD liquidity) and S6, but not targeted. Partner awareness is self-declared and never verified or displayed.	Founder · before P1 beta invites
D-02	Chat encryption vs server-side scanning	Resolved (A §9.2, §21.6)	Full E2EE (MLS). Guardian runs on device and sends score + reason code only. Content reaches the server only through member-disclosed reports or Panic. Source B FR-009's "media scanning in real time" is met on device.	—
D-03	Financial base case	Resolved (A §15.3)	A's illustrative model is the base case (CAC £38, 11% payer rate, 19% churn). B's targets (< 7% churn, > 3× LTV:CAC) are superseded. Thresholds corrected in E-03.	—
D-04	What does the ENVOY tier's "runs outreach" mean?	Default	Envoy <i>proposes</i> intents with rationale; every outbound intent needs a one-tap human approval. Envoy never sends anything to a human as the member (P4; ToS cl. 7.3).	Head of Product · before P3
D-05	GHOST add-on charges for decoy skin, duress PIN and voucher billing, which conflicts with B's "never monetise safety" and C's "discretion is free"	Open	Default: core decoy, duress PIN, Burn, masking, zones and voucher billing are free . GHOST sells multiple decoy skins, custom TTLs and extended ExclusionRing heuristics at £7.99. Revenue impact is to be modelled.	CEO · before P3 pricing
D-06	"Free ENVOY for 6 months for women-identifying users" vs gender-neutral pricing (B) and the Equality Act 2010	Open (counsel)	Default: scarce-side seeding by segment (S4) and city-balance need, not gender. The gender-based variant ships only with a written counsel opinion.	DPO/Counsel · before P1 beta invites
D-07	Contract formats	Default	OpenAPI 3.1 at the edge; Protobuf for gRPC, the agent bus and events (schema registry); generated types on both sides.	Principal Eng · P0
D-08	Biometric ban anchor	Open (counsel)	Default off . Anchors use document, device and payment HMACs only. V1 retains no biometric template (A §8.1).	DPO/Counsel · before P1
D-09	Microservices vs modular monolith for core domain services	Default	Agents are separate deployables (as A requires). Core domain services form a modular monolith (core-svc) with enforced module boundaries, given a 2-person backend team; split on evidence. Identity, ban, media and safety are always separate.	Principal Eng · P0

ID	Decision	Status	Resolution / default	Owner · deadline
D-10	Hash matching of private (E2EE) media	Open (counsel + vendor)	Default: on-device pre-send nudity classifier always; on-device perceptual hash matching against licensed lists where licensing permits. Otherwise rely on reports, StopNCII and the NCII escalation path. Must be addressed in the OSA risk assessment (ToS Q7).	Head of T&S · P0
D-11	In-app purchase in store builds	Default	Web-first. Store builds use reader/link-out entitlements where rules allow; where IAP is required, offer TRYST+ only through IAP, with entitlements unified server-side.	Head of Product · P3
D-12	Delivery timeline	Resolved (A §17)	A's P0-P4 over 24 months, with phase gates, replaces B's 68-week sequential plan.	—
D-13	Launch markets	Resolved (A §14.5)	UK + IE, then EU wave 2, then CA/AU/NZ. US out of scope; never Africa or MENA.	—
D-14	Mode naming	Default	B's SPARK/EMBER/THIRD/QUAD/OPEN as UI labels; A's intent shapes as data values (02 §2.3).	Design · P1
D-15	Concierge tier (B, C)	Default	Deferred beyond P4. A's tiers are canonical.	CEO · P4 review
D-16	Who can sign in, and with what	Resolved (founder, v1.2)	Only the account holder. App and mobile PWA: two biometric factors (device-bound biometric passkey + liveness face match). Desktop: two factors (passkey + registered-phone approval or a second security key). No passwords, SMS or email codes, or staff overrides (02 §3.3).	—
D-17	Members who cannot use face or fingerprint biometrics (disability, device)	Open (counsel)	Default alternative: two registered FIDO2 security keys with PIN, plus a provider video liveness check with assisted human review in place of B2. Required so biometric consent is freely given and to meet the Equality Act (ToS Q14, Q15).	DPO/Counsel · before P1 beta
D-18	Where the B2 face reference is held	Open (counsel + vendor)	Default: held by the liveness provider under contract (TRYST stores only a token); deleted at the provider on erasure. Alternative rejected by default: TRYST-held encrypted template (contradicts A §8.1 "no biometric template").	DPO/Counsel · P0
D-19	Brand identity	Resolved (founder, v1.2)	Founder-supplied logo used exactly as supplied; palette sampled from it (oxblood and gold on night, cream replacing "bone"). Discretion rules still keep the logo off decoy, lock-screen and notification surfaces (01 §3).	—

3. Errata fixed in v1.1

ID	Issue (source)	Fix in v1.1	Where
E-01	A §8.1 lets V1 (liveness only) send intents and open threads, contradicting ToS cl. 5.1 ("adult verified before Intent"), B FR-001 and the OSA expectation that age assurance covers the inbox.	V2 required for discovery, intents, Envoy, threads, media and meets. V0/V1 = onboarding only. min_counterparty_tier default raised to V2.	02 §3.2; FR-001
E-02	A §19.3 L2 computes ban anchors from the ID document number and payment token at ban time , but A §8.1/§10 retain neither, so anchors could never be written.	anchor_candidate HMACs are computed at V2 and held in IDENTITY-DB under the member's keys. They are erased with the account unless a permanent ban copies them to BAN-DB. Disclosed in ToS cl. 15.3.	02 §4.1; 03 §8
E-03	A §15.3 says viability requires "blended CAC < £12". At the stated 11% payer rate and 52% V2 rate, break-even blended CAC per sign-up is £8.18 (£143 × 0.11 × 0.52). £12 breaks even only at ≥ 16% payer rate.	Thresholds table added: £8.18 at 11%, £11.90 at 16%, £13.38 at 18%; 3× LTV:CAC needs £2.73–£4.46.	01 §10.3
E-07	B specifies React Native for mobile; A requires native Swift/Kotlin for security.	Native (A). React Native not used. Shared Rust crypto core instead.	04 §3
E-09	ToS Q8 cites "spec §19.5" for the consortium; it is §19.3 L5.	Corrected in ToS draft 0.9.1.	05 cl. 29
E-10	ToS cl. 17.3 relies on "a false declaration under clause 3.2", but cl. 3.2 contains no declaration. A §19.3 L3 defines a conduct attestation at V2.	New ToS cl. 3.5 (conduct declaration); cl. 17.3 now refers to it.	05 cl. 3.5, 17.3
E-11	A §9.2 media retention of "7 d default" was ambiguous between profile and thread media.	7 d applies to thread media; profile media persists until removed.	02 §7
E-12	A §8.1 says V1 retains "no biometric template", but A §19.3 L2 lists anchor_biometric.	Biometric anchor off by default (D-08).	02 §4.2

ID	Issue (source)	Fix in v1.1	Where
E-13	Sources A and B both call themselves "v1.0 / 17 Sep 2026" (A's cover says 4 Oct 2026, its footer says 17 Sep).	Renamed Source A / Source B with file dates.	00 §2
E-14	B's tiers (Black £24.99, Duo £34.99, Signals, Vault+, Concierge Black) conflict with A's.	A's tiers are canonical; Signals ≈ Keys; Vault+ folded into TRYST+ (extended media); Concierge deferred (D-15).	01 §10.2
E-16	C planned a US launch, which A excludes.	US out of scope. C's US legal notes archived for reference only.	01 §11
E-21	A §11 POST /v1/panic performs a discretion wipe, while A §19.7 defines Panic as emergency escalation and says it must be "distinct from Burn".	Wipe endpoint renamed POST /v1/burn; emergency is POST /v1/safety/panic. Distinct UI controls.	02 §5.3, §5.8; 04 §5, §7
E-23	A §10 couple_link requires both co-sign timestamps to be NOT NULL but has no pending state for the invite flow.	couple_invite table added; couple_link written only on the second co-sign.	02 §4.3
E-26	Slate size given as "12-18" (A §4) and "18" (A §11).	"Up to 18" cards including a 15% exploration floor.	02 §5.5
E-29	A §11 lists POST /v1/handshake as client-callable, but handshakes must start only on mutual intent.	System-initiated only; clients read Briefs and post decisions.	02 §5.6
E-30	A's §17 budget (£5.9M) excludes the £85-140k/yr insurance from A §20.5.	Called out as an addition in 01 §12.	01 §12
E-32	Ashley Madison membership cited as 91M+ (B §1) and 80M+ (A §1).	Both kept as attributed, unaudited claims; external materials must use a current, dated figure.	01 §2
E-31	B places THIRD/QUAD in delivery Phase 4; A treats S3/S5 as first-class and ships VC in P1.	THIRD/QUAD matching in P1 (A); DUO billing in P3.	FR-049

(Gaps in the E-numbering are intentional; IDs are never reused.)

4. Change log

Version	Date	Change	Author
1.0 (Source B)	17 Sep 2026	Developer Specification	Founder
0.1 (Source C)	4 Oct 2026	PRD & business plan draft	Claude Code (draft)
1.0 (Source A)	4 Oct 2026	Consolidated Spec + ToS draft 0.9	Office of the Group CEO
1.1	4 Oct 2026	Merged A + B + C; split into Product / Shared Contracts / Backend / Frontend / ToS; decisions D-01-D-15; errata E-01-E-31; baseline and change control established	Claude Code, for founder review
1.2	4 Oct 2026	Founder logo added exactly as supplied (assets/brand/); brand palette and tokens from the logo; account-holder-only login: two biometric factors on app/mobile PWA, two factors on desktop (D-16-D-18, FR-056-FR-063, NFR-16/17, ToS 0.9.2 cl. 6.5, Q14-Q15); founder product-scope statement, executive product decision, one-sentence pitch and market thesis added verbatim (01 §1-§2), D-01 reopened, E-32; spec folder renamed docs/spec	Claude Code, for founder review